BP DIGITAL BANKING

Arquitectura de soluciones | Propuesta técnica autocontenida

Canales web y móvil • Core bancario • Integridad financiera • Seguridad • AWS • Operación

Versión final — noviembre de 2026

Alcance: propuesta de diseño arquitectónico; no representa una implementación productiva.

Resumen ejecutivo

Estado: propuesta de diseño arquitectónico para evaluación; no representa una implementación productiva

1. Resumen ejecutivo

BP requiere una plataforma de banca digital con SPA y aplicación móvil para consultar datos del cliente y movimientos, realizar transferencias propias e interbancarias y efectuar pagos. La solución reutiliza el Core como fuente de verdad, un sistema complementario para detalle de clientes y un producto OAuth 2.0 existente. Propone una arquitectura de servicios cohesivos con APIs, BFF, adaptadores anticorrupción y eventos para desacoplar notificaciones y auditoría. AWS es una elección propuesta, no un requisito obligatorio del ejercicio

Las decisiones prioritarias son: integridad financiera mediante idempotencia y conciliación; seguridad por diseño mediante OIDC/PKCE, autorización por recurso y verificación facial; continuidad con Multi-AZ y DR; y mantenibilidad mediante DDD, hexagonal y contratos versionados. Las cifras de SLO, RTO, RPO y carga son hipótesis de diseño que requieren validación de BP

2. Problema, alcance y restricciones

La experiencia digital incluye dos canales, consulta histórica, perfil básico y detallado, transferencias, pagos, onboarding facial, autenticación posterior y notificación de movimientos con mínimo dos sistemas. Toda acción del cliente debe producir evidencia de auditoría. Un patrón de persistencia para clientes frecuentes reduce lecturas repetitivas sin convertir el caché en fuente de verdad

No se plantea sustituir Core, construir un IdP nuevo ni persistir datos biométricos en el canal por defecto. La topología de integración con red interbancaria, capacidades de terceros y reglas regulatorias deben confirmarse

3. Arquitectura de canales

Se selecciona React + TypeScript para SPA por composición de componentes y verificación estática de contratos, frente a Angular como alternativa con estructura prescriptiva. Se selecciona Flutter para iOS/Android por UI y código compartidos, frente a React Native que aprovecha experiencia JavaScript pero requiere evaluar integración nativa del SDK facial. El acceso web usa BFF y cookies de sesión seguras como patrón preferido; móvil usa navegador del sistema para Authorization Code + PKCE. El IdP existente se configura con OIDC; la biometría local habilita credenciales/passkeys, mientras onboarding facial realiza verificación inicial de identidad

4. Servicios y datos

BFF orquesta canales; Perfil consulta Core y fuente complementaria con Cache-Aside; Movimientos consulta histórico del Core; Transacciones ejecuta transferencias/pagos y gestiona idempotencia, estado y conciliación; Onboarding integra proveedor facial; Notificaciones y Auditoría consumen eventos. Aurora guarda estado propio y outbox, Redis acelera lecturas autorizadas, EventBridge/SQS desacopla procesamiento asíncrono. Ningún servicio lee tablas privadas de otro servicio; el Core conserva saldos y movimientos autoritativos

5. Flujos críticos

Consulta frecuente: autenticación, autorización por titularidad, lectura Redis con TTL, consulta a Core en miss, actualización del caché y respuesta. Invalidar al cambiar datos; no cachear información cuya frescura no pueda garantizarse

Transferencia: validar identidad, titularidad, límites y step-up; registrar clave idempotente y estado; invocar Core/red mediante adaptador; confirmar solo con evidencia del sistema de registro; persistir estado y outbox en transacción local; publicar y consumir eventos de forma idempotente. Timeout ambiguo deriva a conciliación, no a reenvío automático

Onboarding: crear sesión de verificación, ejecutar documento/liveness con SDK autorizado, recibir callback firmado y protegido contra replay, revisar excepciones y habilitar credenciales en IdP únicamente al aprobar. No confundir liveness con autorización de transferencias

Notificación y auditoría: publicar evento outbox tras commit, consumir con deduplicación, enviar por correo y SMS según política y registrar auditoría con integridad/retención. Fallo del proveedor no revierte operación confirmada

6. Infraestructura y operación

CloudFront/WAF y API Gateway protegen borde. ECS Fargate despliega servicios sin estado en dos AZ privadas, con integración privada compatible. Aurora y Redis Multi-AZ soportan datos propios y caché. EventBridge/SQS/DLQ maneja eventos, reintentos y excepciones. CloudWatch/OpenTelemetry agrega métricas, trazas y logs sanitizados. DR regional depende de respaldos cifrados, copias permitidas y simulacros. Multi-AZ no equivale a continuidad multi-región

7. Seguridad, privacidad y cumplimiento

Aplicar defensa en profundidad: TLS, WAF, control de tasa, validación de tokens, autorización fina, IAM mínimo privilegio, secretos rotados, cifrado, segmentación, auditoría y pruebas de acceso cruzado. Para Ecuador, revisar aplicabilidad de LOPDP y normativa bancaria con asesoría legal y de cumplimiento. ISO 27001, OWASP ASVS/MASVS y NIST son referencias de buenas prácticas; PCI DSS solo si entra en alcance información de tarjetas regulada. Los datos biométricos requieren tratamiento reforzado y justificación legal

8. Atributos de calidad y costo

Los objetivos propuestos son disponibilidad mensual de canal 99,95 %, p95 interno de consultas <=500 ms, RTO <=60 minutos y RPO <=15 minutos para datos propios, sujetos a validación. Las pruebas deben cubrir caída de AZ, recuperación, saturación de Core, timeouts ambiguos, duplicados, fuga de datos, colas y notificaciones. El presupuesto se estima por consumo de Fargate, API Gateway, CDN/WAF, Aurora, Redis, eventos, red, telemetría, backups y secretos, con escenarios 0,5x, 1x y 3x. No se presentan precios no cotizados

9. Riesgos residuales

Dependencia de Core y terceros, semántica de reversos/conciliación, disponibilidad del IdP, residencia de datos, costos de red y observabilidad, y retención de auditoría. Se mitigarán mediante contratos, pruebas de integración, revisión legal, FinOps y simulacros

10. Conclusión

La propuesta de BP Digital Banking responde a los objetivos del ejercicio mediante una arquitectura omnicanal que separa las responsabilidades de los canales, los servicios de negocio y las integraciones bancarias. El Core conserva la autoridad sobre saldos y movimientos, mientras que los servicios digitales gestionan la experiencia del cliente, la autorización por recurso y la trazabilidad de las operaciones

Las decisiones de idempotencia, conciliación, outbox transaccional, controles antifraude y seguridad por capas protegen la integridad de los flujos financieros. La infraestructura propuesta en AWS aporta mecanismos de disponibilidad, observabilidad y recuperación acordes con los atributos de calidad definidos como objetivos de diseño

En conjunto, la arquitectura constituye una base coherente, extensible y mantenible para la evolución de la banca digital de BP. Su valor reside en la claridad de las responsabilidades, la consistencia de los contratos y la capacidad de integrar sistemas existentes sin comprometer la seguridad ni la integridad financiera

Requisitos, diseño y decisiones de plataforma

Contexto y alcance

1. Alcance y límites

Plataforma omnicanal para consultar perfil/productos/movimientos, transferir entre cuentas propias e interbancarias y realizar pagos. El Core Bancario es sistema de registro para cuentas y movimientos. El sistema complementario proporciona detalles del cliente. La red interbancaria y los proveedores de verificación facial/notificaciones son dependencias externas

No se sustituye el Core ni se almacenan saldos definitivos en caché. El producto de identidad OAuth2 ya existe y se configura; no se construye un nuevo servidor OAuth

2. Propuesta de arquitectura

Canales: SPA React + TypeScript y móvil Flutter; comunicación exclusiva por HTTPS con BFF / API Gateway

Identidad: IdP corporativo existente con OpenID Connect, Authorization Code + PKCE (S256), state, nonce y redirect URIs exactos; en móvil navegador del sistema, nunca webview embebida. Passkeys/WebAuthn opcionales si el IdP los soporta. Huella/rostro del dispositivo solo desbloquea credencial local o passkey; no equivale a validar identidad de onboarding

Onboarding: flujo separado de identidad documental, liveness y cotejo facial por proveedor, con revisión de excepciones, privacidad, trazabilidad y registro en IdP solo después de verificación

Borde: CloudFront + WAF, API Gateway; controles de tasas, validación JWT en límite apropiado y autorización fina en servicios

Aplicación: servicios de perfil, movimientos, transferencias/pagos, onboarding, notificaciones y auditoría; contenedores ECS Fargate Multi-AZ; cada servicio dueño de sus datos derivados

Integración: adaptadores anticorrupción hacia Core, sistema complementario, red interbancaria y proveedores; timeouts, circuit breakers, idempotencia y correlación

Datos: Aurora PostgreSQL para estado transaccional propio y outbox; ElastiCache Redis para caché de perfiles de lectura (Cache-Aside con TTL e invalidación); no cachear credenciales ni saldo autoritativo

Eventos: Transactional Outbox -> publicador -> EventBridge/SQS -> notificaciones y auditoría; dos canales de notificación (por ejemplo SMS y correo electrónico), con proveedores alternativos y DLQ. SQS Standard implica duplicados posibles: consumidores idempotentes

Operación: CloudWatch/OTel, logs redactados, alarmas, backups y restauración probada; infraestructura multi-AZ y plan DR regional según requisitos pactados

3. Decisiones transversales

DDD y arquitectura hexagonal: los casos de uso financieros no dependerán de SDKs de nube ni formatos del Core

Separación CQRS ligera: lecturas de perfil/movimientos separadas de comandos de transferencia; no se requiere event sourcing

Transferencias: validación de propiedad, límites, antifraude y autorización reforzada para operaciones sensibles; API responde operación con identificador y estado. Si Core/red responde ambiguamente, consultar/conciliar antes de reintentar. Idempotencia evita doble ejecución

Auditoría: generación síncrona del registro crítico transaccional junto al outbox; entrega asíncrona a repositorio central inmutable con retención gobernada. No afirmar “exactly once” de extremo a extremo

Resiliencia: la caída de notificaciones no debe revertir una transferencia confirmada; se reintenta de forma segura y se alerta si hay demoras

HA/DR: zonas múltiples, sin dependencia de una sola instancia, backups, simulacros y estrategia regional futura; objetivos cuantitativos son supuestos, no SLA certificados

4. Riesgos y mitigaciones

Riesgo	Mitigación
Latencia/caída del Core	bulkhead, timeout, circuit breaker; degradación controlada solo para consultas no críticas
Transferencia duplicada	idempotency key persistida, identificador de negocio y conciliación
Suplantación de identidad	liveness, validación documental, revisión de excepciones, MFA adaptativa
Exposición de PII	minimización, cifrado, IAM, masking, políticas de retención
Eventos duplicados/perdidos	outbox transaccional, DLQ, reintentos e idempotencia en consumidores
Dependencia de nube/región	Multi-AZ y plan de restauración cross-region verificado
Sobrecosto	escalado por demanda, presupuestos y alertas, servicios administrados

5. Contratos a precisar

Asegurar clasificación transaccional (propias/interbancarias/pagos), semántica del Core y red, estados y reversos, modelo de autorizaciones de cuentas, volumen, SLA y requerimientos regulatorios concretos antes de implementación

La matriz de trazabilidad y los ADR se incluyen en este documento

Arquitectura frontend web y móvil

La propuesta separa la experiencia de usuario de las reglas financieras, la identidad y las integraciones bancarias. Ambos canales utilizan contratos API versionados y no acceden directamente al Core ni a las bases de datos de los servicios. React + TypeScript y Flutter son las tecnologías propuestas; su selección se fundamenta en mantenibilidad, reutilización y experiencia omnicanal

1. Arquitectura frontend web — React y TypeScript

Componente	Responsabilidad arquitectónica	Decisión de diseño
SPA React + TypeScript	Vistas de perfil, movimientos, transferencias, pagos, seguimiento de operaciones y onboarding	Componentes reutilizables, modelos tipados derivados de OpenAPI y separación entre presentación y acceso a datos
Router y control de navegación	Rutas públicas, autenticadas y sensibles; manejo de expiración	Los guards mejoran la navegación, pero la autorización efectiva reside en BFF y servicios
Estado de servidor	Consultas, invalidación, revalidación y estados de carga/error	Caché efímera por usuario; nunca fuente autoritativa de saldos ni almacenamiento persistente de PII
Estado de interfaz	Formularios, pasos, confirmaciones y mensajes	No almacenar credenciales ni tokens en localStorage
Cliente BFF	Acceso a capacidades de negocio y composición de respuestas	Contratos tipados, correlación de solicitudes, errores de dominio y límites de tiempo
Experiencia y accesibilidad	Diseño responsive, estados vacíos, errores, confirmaciones y formatos locales	Navegación accesible, mensajes claros y confirmación explícita de operaciones sensibles
Entrega web	Distribución de recursos estáticos versionados	CloudFront y origen privado como patrón; HTTPS, CSP, política de caché y reversión de versión

Flujo web: navegador → CloudFront/WAF → SPA → BFF/API → servicios de dominio. La autenticación utiliza el IdP existente mediante OIDC; el BFF administra la sesión web con cookies Secure, HttpOnly y SameSite y protección CSRF acorde con los dominios desplegados. El frontend no almacena secretos del Core ni decide titularidad, límites o autorización de operaciones

2. Arquitectura frontend móvil — Flutter

Componente	Responsabilidad arquitectónica	Decisión de diseño
Flutter Android/iOS	Interfaz y navegación adaptativas con lógica de presentación compartida	Encapsular integraciones nativas y dependencias de plataforma
Estado de pantalla y operación	Consultas, progreso, errores y seguimiento de transacciones	Una respuesta HTTP 202 indica aceptación de la solicitud, no confirmación financiera
Cliente API	Solicitudes HTTPS tipadas, correlación, timeouts y manejo de errores	Idempotency-Key estable para comandos; no repetir débitos ante respuestas ambiguas
Autenticación	Authorization Code + PKCE S256 con navegador del sistema	Deep links verificados y tokens conforme a política del IdP; evitar WebView embebida
Almacenamiento seguro	Credenciales estrictamente necesarias	Keychain/Keystore; no persistir biometría ni secretos en almacenamiento plano
Biometría local	Desbloqueo de credencial local o passkey, si corresponde	No equivale a la verificación facial remota del onboarding
Onboarding facial	Integración con SDK del proveedor mediante adaptador	Verificación documental/liveness y callback autenticado procesado en backend
Distribución	Artefactos firmados para las tiendas móviles	Versionado, integridad de aplicación y gestión de compatibilidad

Flujo móvil: aplicación Flutter → navegador del sistema/IdP para autenticación → API Gateway/BFF móvil según contrato → servicios de negocio. El dispositivo presenta el estado de una transferencia mediante consulta de operación; solo el Core y los mecanismos de conciliación pueden confirmar el resultado financiero

3. Alternativas y justificación

Criterio	Flutter — propuesta	React Native — alternativa
Experiencia visual	Widgets propios y consistencia entre plataformas	Ecosistema JavaScript y componentes de plataforma
Código compartido	Lógica de presentación y UI en Dart	Reutilización de conocimientos React/TypeScript
SDK facial y seguridad	Adaptadores/plugins nativos cuando se requieran	Bridges/módulos nativos cuando se requieran
Riesgos	Disponibilidad de plugins y capacidades del equipo	Compatibilidad de módulos y versiones nativas

Se propone Flutter para unificar la experiencia móvil y React + TypeScript para el canal web. La decisión no supone que ambos canales deban compartir componentes de interfaz: comparten contratos, reglas de experiencia, terminología, observabilidad y políticas de seguridad, manteniendo implementaciones independientes

4. Responsabilidades y límites transversales

Presentación: accesibilidad, navegación, validaciones de formato y confirmación de intención del cliente; nunca autorización definitiva ni ejecución directa en Core

Identidad: el IdP existente autentica; BFF/API y servicios verifican sesión, permisos y titularidad. Onboarding facial y biometría local son procesos distintos

Integridad financiera: el canal conserva la referencia de operación e idempotencia; los servicios de transacciones gestionan estados, conciliación y resultado autoritativo

Privacidad: minimizar datos en cachés, telemetría y almacenamiento local; limpiar el estado sensible al cerrar sesión

Resiliencia de experiencia: presentar estados pendientes y errores recuperables sin transformar timeouts en confirmaciones ni reenviar automáticamente operaciones financieras

Observabilidad: propagar identificadores de correlación sin incluir credenciales, biometría o PII sensible en logs

Estas decisiones complementan los diagramas C4 y de secuencia existentes sin modificar sus componentes ni introducir nuevas dependencias de negocio

Requisitos y atributos de calidad

Estado: propuesta para revisión de BP. Ninguna cifra es una medición real ni requisito explícito de DEVSU

Atributo	Escenario verificable	Objetivo inicial (supuesto)	Mecanismo	Evidencia requerida
Disponibilidad	Falla una AZ durante consultas	99.95% mensual del canal, condicionado a Core	ECS Fargate en >=2 AZ, ALB, Aurora Multi-AZ, Redis failover	Game day y SLI por dependencia
Latencia	Consulta frecuente con caché caliente	p95 <= 500 ms del tramo BP, sin Core externo	Redis cache-aside, índices, conexiones persistentes	Prueba de carga y trazas
Transferencias	Timeout después de enviar a Core/red	Sin doble débito por reintento del cliente	Clave idempotente persistida, referencia externa, estado PENDIENTE_CONCILIACION	Prueba con timeout e inspección de Core
Auditoría	Fallo de cola durante confirmación	Evidencia durable en BD local antes de confirmar	Escritura en transacción local + outbox, envío posterior	Inyección de fallo y reconciliación
Mensajería	Proveedor email no responde	SMS según política, sin bloquear transacción	Reintentos exponenciales, DLQ, proveedor/canal alterno	Test de failover y duplicados
DR	Pérdida de región primaria	RTO <=60 min, RPO <=15 min para estado propio (supuesto)	Backups cifrados, copias cross-region, runbook de restauración	Simulacro de restauración
Seguridad	Token robado o uso de cuenta ajena	Rechazo de autorización	Validar iss/aud/exp, scopes, ABAC y step-up	Pruebas negativas de seguridad
Operación	Contenedor falla health check	Recuperación automática sin intervención	ECS service health check y autoscaling	Simulación de crash
Privacidad	Solicitud de eliminación de datos	Tratamiento conforme política legal	Inventario, minimización, retención y excepciones regulatorias	Revisión DPO/legal

Diseño de HA

Distribuir tareas en dos o más AZ; servicios sin estado; endpoints privados para acceso a datos; Aurora con failover; Redis Multi-AZ según criticidad; colas gestionadas; sin dependencias síncronas innecesarias para notificaciones. No asumir que Multi-AZ protege contra falla regional

DR

Definir clasificación de datos por servicio, respaldos automáticos cifrados, copia fuera de región cuando la residencia de datos lo permita, prueba de restauración trimestral propuesta, roles y runbook de conmutación. Los objetivos RTO/RPO se validarán con BP; Core y red interbancaria pueden tener objetivos diferentes

Observabilidad y auto-healing

OpenTelemetry: trace-id/correlation-id entre BFF, servicios y adaptadores. Métricas RED (rate/errors/duration), saturación, tasa de fallos de proveedor, edad de outbox, profundidad DLQ, tiempo de conciliación y discrepancias de auditoría. Logs estructurados sin credenciales ni PII. Alarmas y on-call con runbooks; health checks y reemplazo de tareas ECS

Política de degradación

Perfil: servir caché solo si la frescura y la clasificación de dato lo permiten, señalando desactualización

Movimientos: si Core falla, no inventar histórico

Transferencias: ante respuesta ambigua, estado pendiente y conciliación, nunca reintento ciego

Notificaciones: desacopladas de la confirmación bancaria

Operación detallada AWS

Ver diseño de despliegue, SLI, alarmas y runbooks y modelo de capacidad. Los objetivos 99.95%, p95 500 ms, RTO 60 min y RPO 15 min son hipótesis pendientes de validación y no garantías comprobadas

Integración bancaria y contratos

Estado: propuesta, sin contrato firmado con Core, gateway MX ni proveedor de pagos. No confundir el contrato del canal BP con el contrato de integración bancaria. Referencias: INT-002/006/007/008, flujos, ADR-008, ADR-009

Integración Core con Apache Camel (opcional): El ADR-010 propone incorporar Camel dentro del adaptador Core cuando existan múltiples protocolos o transformaciones legacy. No se plantea un ESB central: la autorización, idempotencia, gestión de estados y conciliación permanecen en los servicios de dominio. Para una integración REST simple se mantiene un cliente HTTP nativo

1. Límites y modelo

API de canal: POST /transfers, GET /transfers/{operationId}, POST /payments, GET /payments/{operationId}. El BFF valida sesión; Transacciones valida titularidad y permisos en cada operación

Core: es autoridad de saldos, movimientos, débitos y confirmación final. La persistencia BP almacena la intención, referencias, evidencia y estado de orquestación, no un libro mayor alterno

MX: adaptador opcional por ruta contratada. pacs.008 es mensaje interbancario; no exponer XML MX al cliente. pacs.002 requiere interpretar el estado concreto y el perfil; un ACK de transporte no equivale a liquidación

Antifraude: decisión externa no autoriza titularidad. Evaluación atada a hash canónico, operationId, versión de política y vencimiento. REVIEW/BLOCK/UNAVAILABLE alto riesgo impiden despacho financiero

Idempotencia: ámbito lógico actorRef + operationType + Idempotency-Key, hash de campos de negocio y referencia estable. La misma clave con diferente hash produce 409. El mismo comando concurrente produce una sola intención durable

Orden de ejecución: verificar identidad/titularidad/límites -> reservar idempotencia -> evaluación antifraude -> registrar decisión -> preparar despacho con referencia durable -> invocar Core/gateway -> registrar respuesta verificable o pendiente de conciliación -> outbox. Una evaluación externa no debe mantener abierta una transacción de BD

2. Contrato de solicitud y respuesta

Solicitud sintética:

```
POST /transfers HTTP/1.1
Authorization: Bearer <token>
Idempotency-Key: trf-20261106-001
Content-Type: application/json

{
  "type": "INTERBANK",
  "sourceAccountId": "acc-demo-001",
  "destination": {"bankCode": "DEMO01", "accountRef": "masked-demo-987"},
  "amount": "125.40",
  "currency": "USD",
  "concept": "Pago de ejemplo"
}
```

Respuesta inicial sintética (no implica débito completado):

```
{
  "operationId": "op-demo-001",
  "status": "RECEIVED",
  "correlationId": "corr-demo-001",
  "statusUrl": "/transfers/op-demo-001"
}
```

La implementación debe utilizar importes decimales exactos, precisión y escala por moneda, nunca float binario. No permitir que el cliente envíe actorRef, titularidad verificada, decisión de riesgo ni estado final como fuente confiable. GET responde solo a un actor autorizado para la operación

Política de CHALLENGE: la decisión CHALLENGE de INT-007 no es un estado persistente adicional. Se representa como una acción de autenticación reforzada dentro de RISK_PENDING. Solo una comprobación satisfactoria, vinculada a la operación y todavía vigente, permite AUTHORIZED. Un desafío vencido, fallido o no concluyente mantiene la operación sin despacho y conduce a revisión o rechazo según política aprobada

3. Estados y transiciones

Estado	Significado	Transiciones admitidas
RECEIVED	Intención persistida, aún no enviada	RISK_PENDING, REJECTED
RISK_PENDING	Evaluación de riesgo o step-up pendiente	AUTHORIZED, REVIEW_REQUIRED, REJECTED
REVIEW_REQUIRED	Revisión humana, sin envío al Core	AUTHORIZED, REJECTED, EXPIRED
AUTHORIZED	Política y riesgo aprobados, no implica ejecución	SUBMITTED, REJECTED, EXPIRED
SUBMITTED	Despacho remoto iniciado con referencia durable	COMPLETED, REJECTED, PENDING_RECONCILIATION
PENDING_RECONCILIATION	Resultado remoto no concluyente	COMPLETED, REJECTED, MANUAL_REVIEW
MANUAL_REVIEW	Reconciliación automática agotada	COMPLETED, REJECTED, PENDING_RECONCILIATION
COMPLETED	Evidencia de confirmación final del sistema autoritativo	Terminal; devoluciones son operaciones separadas
REJECTED	Rechazo definitivo verificado o antes del despacho	Terminal
EXPIRED	Intención no despachada caducó	Terminal

Invariante: REJECTED después de SUBMITTED exige rechazo remoto concluyente; un timeout jamás se traduce a rechazo definitivo. No permitir COMPLETED por un mero HTTP 200 de aceptación o ACK MX

4. Errores públicos

HTTP	Código lógico	Causa	Reintento del cliente
400	INVALID_REQUEST	Sintaxis o datos inválidos	Corregir datos y nueva clave
401	UNAUTHENTICATED	Credencial ausente o inválida	Reautenticar
403	NOT_AUTHORIZED	No titularidad, límite o permiso	No
404	OPERATION_NOT_FOUND	No existe o no es visible al actor	No divulgar existencia
409	IDEMPOTENCY_CONFLICT	Misma clave, diferente comando	No; corregir y nueva clave
409	INVALID_STATE_TRANSITION	Operación no admite acción	Consultar estado
422	BUSINESS_RULE_REJECTED	Regla de negocio, sin despacho	Corregir datos
202	PROCESSING / RECONCILING	Resultado pendiente	Consultar estado; no repetir débito
429	RATE_LIMITED	Límite de uso	Backoff; misma clave si corresponde
503	DEPENDENCY_UNAVAILABLE	Sin capacidad de procesar antes del despacho	Consultar operación existente antes de crear otra

Observación: si existe operación durable, devolver operationId y estado aun cuando el proveedor esté caído. No exponer causas antifraude internas o referencias bancarias sensibles

5. Contrato del adaptador Core / gateway

Campo o capacidad	Regla de diseño	Pendiente contractual
operationId	Generado por BP, estable	Longitud, formato y unicidad
externalReference	Persistida antes de despachar	Si Core permite consulta/idempotencia por referencia
providerStatus	Normalizado sin perder estado original	Mapa de códigos y terminalidad
providerMessageId	Correlación MX y reenvíos	BizMsgIdr, MsgId, InstrId, EndToEndId, TxId según contrato
Autenticidad	TLS/mTLS y firma cuando aplique	Canal, certificados, rotación
Timeout	Si despacho pudo ocurrir, resultado ambiguo	Umbrales y ventana de consulta
Reverso / devolución	Flujo separado, no rollback local	Soporte, reglas, compensación contable
AML / sanciones	Control institucional distinto de antifraude	Responsable y punto de aplicación

6. Casos de verificación

ID	Preparación	Aserción
FIN-01	Dos POST concurrentes con igual clave y payload	Una intención y máximo un despacho remoto
FIN-02	Timeout tras débito Core	Estado PENDING_RECONCILIATION; sin segundo despacho
FIN-03	Core confirma y BP cae antes de guardar	Recuperación por referencia, no duplicación
FIN-04	Proveedor rechaza pago	REJECTED solo con evidencia concluyente
FIN-05	Consulta remota no concluyente	MANUAL_REVIEW / pendiente, nunca COMPLETED inferido
FIN-06	Relay publica dos veces	Consumidor idempotente y auditoría correlacionada
FIN-07	Misma clave con importe distinto	409 y ningún despacho nuevo
FIN-08	Cambio de beneficiario tras ALLOW	Se invalida evaluación y no se envía
FIN-09	Usuario consulta operación ajena	404/403 sin revelar datos
MX-01..08	Esquemas y mensajes sintéticos versionados	XSD, perfil, XXE, duplicados y estados conforme ADR-009

Alcance de los escenarios FIN/MX: Los casos FIN-01..09 y MX-01..08 definen comportamientos esperados de los contratos y criterios de aceptación del diseño. Su inclusión no supone homologación con el Core ni con proveedores externos

7. Decisiones abiertas antes de producción

1. Confirmar APIs, SLA, consulta por referencia y semántica de estados del Core
2. Determinar qué rutas realmente utilizan MX, el gateway autorizado, el release CBPR+ y esquemas XSD
3. Confirmar límites, step-up, reglas de fraude, retención y revisión humana con Riesgos
4. Aprobar ventanas de conciliación, tiempos de escalamiento y responsabilidad operacional
5. Revisar la especificación con equipos Core, Pagos, Riesgos, Seguridad y Cumplimiento

Flujos financieros y consistencia

Invariantes de negocio propuestas

1. Un identificador idempotente por cliente/operación representa un solo intento lógico; reutilizar clave con distinto payload devuelve conflicto
2. Ninguna transferencia se marca COMPLETED sin confirmación verificable del sistema de registro o conciliación concluyente
3. Timeout de Core/red tras envío implica estado PENDING_RECONCILIATION, nunca reenvío automático ciego
4. El saldo definitivo pertenece al Core; la base del canal no sustituye el libro mayor

5. Toda transición relevante genera evidencia local durable junto al estado de la operación y un evento outbox en la misma transacción local

6. Auditoría y notificaciones consumen eventos de forma idempotente; su indisponibilidad no cambia una operación financiera ya confirmada

7. La autorización se evalúa contra el titular y las facultades vigentes en backend, no contra parámetros del frontend

Modelo de estados propuesto

RECEIVED -> RISK_PENDING -> AUTHORIZED -> SUBMITTED -> COMPLETED | REJECTED | PENDING_RECONCILIATION, con REVIEW_REQUIRED, MANUAL_REVIEW y EXPIRED cuando correspondan. El estado VALIDATING es una actividad de aplicación, no un estado persistido del contrato

Desde PENDING_RECONCILIATION solo un proceso de consulta/conciliación confiable puede resolver COMPLETED o REJECTED; casos no concluyentes escalan a intervención. No se asume que todos los proveedores admitan cancelación o reverso

Patrón Outbox

En una transacción Aurora local: actualizar estado, registrar referencia de auditoría y escribir evento outbox. Publicador separado extrae pendientes, publica al bus y marca entrega. Fallos entre publicación y marcado pueden duplicar mensajes; eventId y transactionId permiten deduplicación. Almacén de auditoría inmutable requiere diseño de retención y pruebas adicionales

Pruebas de aceptación de diseño

ID	Escenario	Criterio
TI-01	20 peticiones concurrentes con igual clave	Una ejecución lógica hacia Core
TI-02	Timeout después de ejecución externa	No hay segundo débito; conciliación
TI-03	Fallo entre commit y publicación	Outbox pendiente se publica al recuperar
TI-04	Evento duplicado	No duplicar auditoría ni notificación lógica
TI-05	Usuario solicita cuenta ajena	403 y evidencia segura
TI-06	Notificador caído	Transferencia permanece confirmada; DLQ/alerta

Alcance: TI-01..TI-06 son criterios de aceptación del diseño para integridad, auditoría y resiliencia; no representan resultados de una ejecución productiva

Autenticación, seguridad y regulación

Alcance normativo

El reto pide mencionar elementos normativos pero no identifica jurisdicción ni categoría regulatoria de BP. Se adopta Ecuador como supuesto de trabajo, sujeto a validación legal. Evaluar Ley Orgánica de Protección de Datos Personales (LOPDP), reglamentación aplicable, disposiciones de la Superintendencia de Bancos para seguridad y continuidad, y reglas del sistema de pagos según operación. ISO/IEC 27001, OWASP ASVS, OWASP MASVS y NIST son referencias de buenas prácticas, no se presentan automáticamente como leyes obligatorias. PCI DSS solo aplica si el alcance incorpora datos de tarjetas sujetos al estándar

Amenazas y controles

Amenaza	Control propuesto	Validación
Robo de token	OIDC, PKCE S256, cookies HttpOnly para web/BFF, almacenamiento seguro móvil, revocación y expiración	Pruebas de sesión
IDOR / acceso cruzado	Autorización por titularidad de cuenta en backend, scopes + atributos; nunca confiar en accountId enviado	Tests negativos
Suplantación facial	Proveedor liveness/documento, callback firmado, antifraude y revisión manual	Pruebas de fraude
Doble pago	Idempotencia, referencia única, conciliación, aprobación reforzada	Inyección de fallos
Fuga PII	TLS, cifrado en reposo KMS, masking, minimización y retención	Revisión de datos
Ataque DDoS/bots	WAF, rate limiting, protección por canal	Prueba controlada
Compromiso de secretos	Secrets Manager, rotación, IAM mínimo privilegio	Auditoría de permisos
Manipulación de evidencia	Outbox transaccional, archivo inmutable, sellado temporal, acceso segregado	Prueba de integridad

Autenticación

Authorization Code + PKCE para cliente público móvil; navegador de sistema, redirect URI validado

Para SPA, preferir BFF que maneje tokens del lado servidor y sesión por cookie segura, con protección CSRF; evaluar configuración real del IdP

Validar JWT por issuer, audience, signature, expiry y claims; no usar token de ID como token de acceso

Step-up para transferencias de riesgo; evaluar passkeys/WebAuthn si IdP soporta

La prueba facial de onboarding NO es equivalente a autenticación biométrica local posterior

Registrar consentimiento/base legal apropiada y minimización para datos biométricos; no conservar imágenes o plantillas en servicios BP salvo obligación justificada

Auditoría

Registrar quién, qué, cuándo, resultado, canal, referencia, trace-id y versión de política; no guardar contraseñas, tokens ni datos biométricos. Escritura crítica junto a transacción local/outbox; consumo idempotente y retención inmutable con control de acceso y políticas legales. Probar reconciliación entre operaciones y eventos

Límites de confianza

Internet -> WAF/API Gateway -> BFF/servicios privados -> Core/red/proveedores. Controlar egreso, DNS, certificados, rotación de claves y callbacks de terceros. Evitar acceso directo de frontend a bases de datos

Evaluación de vulnerabilidades y controles antifraude

El modelo de amenazas detalla riesgos SEC-01 a SEC-16, controles, severidad inherente y riesgo residual objetivo. La existencia de un control en el diseño no demuestra que la vulnerabilidad esté corregida; requiere pruebas y evidencias

La integración de un proveedor antifraude externo se ubica antes del envío de transferencias y pagos al Core, con decisiones ALLOW, CHALLENGE, REVIEW, BLOCK y UNAVAILABLE. BP conserva la autorización final, el control de titularidad y la política de contingencia. La evaluación antifraude no reemplaza AML/sanciones

La mensajería ISO 20022 / SWIFT MX se propone detrás de un gateway bancario institucional. Incluye validación XSD, reglas CBPR+, protección XXE, correlación de mensajes y distinción entre aceptación y liquidación. No se presume que toda transferencia local utilice SWIFT

Amenazas y controles

Método: STRIDE por frontera de confianza, priorización cualitativa inherente y residual estimada, no evaluación cuantitativa certificada. La severidad residual supone controles implementados y probados; en el diseño actual sigue siendo riesgo abierto

Fronteras de confianza

T1 Internet -> CloudFront/WAF/API Gateway; T2 canal -> IdP/BFF; T3 ALB -> ECS privado; T4 servicio -> Core/gateway SWIFT/proveedores; T5 ECS -> datos, colas y auditoría; T6 CI/CD -> cuenta AWS; T7 operador -> evidencias y datos

Registro de riesgos

ID	Amenaza / STRIDE	Inherente	Controles preventivos / detectivos	Residual objetivo	Evidencia
SEC-01	Account takeover / spoofing	Crítico	OIDC PKCE, BFF cookie segura, MFA adaptativa, revocación, detección de dispositivo	Medio	Pentest sesión y FRD-01
SEC-02	BOLA/IDOR en cuentas	Crítico	ABAC/titularidad backend, deny-by-default, tests cross-account	Bajo	Pruebas negativas por API
SEC-03	CSRF/XSS y robo de sesión web	Alto	SameSite/HttpOnly/Secure, CSRF, CSP, escape de salida, sin tokens en SPA	Medio	OWASP ASVS
SEC-04	API abuse, bots y DDoS	Alto	WAF, rate-limit, throttling, detección anomalías, límites por usuario	Medio	Simulación controlada
SEC-05	Doble débito por replay/timeouts	Crítico	Idempotencia, estado durable, consulta Core, conciliación	Medio	FIN-01/02/03
SEC-06	Manipulación de decisión antifraude	Crítico	TLS/mTLS, firma o autenticación de respuestas, hash de operación, expiración	Medio	FRD-02/03
SEC-07	Exfiltración de PII al proveedor	Alto	Minimización, contrato, cifrado, egress control, retención, DLP	Medio	Revisión legal y de datos
SEC-08	XXE, XML bomb, mensaje MX adulterado	Crítico	Parser seguro, DTD off, XSD + perfil, tamaño/profundidad, firma/canal	Medio	MX-02/04
SEC-09	Fraude en onboarding/callback replay	Alto	Liveness, callback firmado, nonce, dedupe, revisión manual	Medio	Pruebas de callback
SEC-10	Compromiso IAM/secretos AWS	Crítico	IAM mínimo, roles separados, KMS, Secrets Manager, rotación, CloudTrail	Medio	IAM Access Analyzer
SEC-11	Movimiento lateral en VPC	Alto	SG por servicio, endpoints privados, egress restringido, patching	Medio	Revisión de red
SEC-12	Alteración/supresión de auditoría	Crítico	Outbox, append-only, reconciliación, segregación, Object Lock si aplica	Medio	AUD-01..08
SEC-13	Imagen maliciosa / supply chain	Alto	SAST, SCA, SBOM, escaneo ECR, firmas, permisos CI mínimos	Medio	Evidencia pipeline
SEC-14	Región indisponible / ransomware	Alto	Backups cifrados, aislamiento de copias, restauración probada, runbooks	Medio	AWS-06
SEC-15	Acceso privilegiado indebido	Alto	MFA fuerte, JIT/PAM, segregación, break-glass auditable	Medio	Auditoría de roles
SEC-16	Confusión de estados SWIFT	Crítico	Mapping explícito, validación estado final, conciliación y pruebas	Medio	MX-06/07

Riesgos que no desaparecen por el diseño

Un token válido no demuestra titularidad; controles antifraude tampoco reemplazan autorización

WAF no corrige vulnerabilidades de lógica de negocio

KMS no evita exfiltración por una aplicación con permisos legítimos comprometida

Multi-AZ no resuelve pérdida regional, Core indisponible o fraude interno

ISO 20022/XSD no prueba autenticidad ni cumplimiento CBPR+ completo

Un proveedor externo puede equivocarse o estar caído; la decisión final de BP requiere gobierno

La auditoría de negocio no se sustituye con CloudTrail

Plan de verificación priorizado

P0: BOLA/IDOR, doble débito, antifraude fail-closed, parsing XML seguro, protección de secretos, integridad de auditoría. P1: sesión, WAF/rate limits, callbacks, supply chain, restauración, permisos y egress. P2: tuning de falsos positivos, optimización de detección y controles de costo

Cada riesgo necesita responsable, evidencia de prueba, resultado, fecha y aceptación formal del riesgo residual antes de producción. No afirmar que una vulnerabilidad está corregida por haberla documentado

Alta disponibilidad y recuperación

Estado: arquitectura objetivo propuesta, no infraestructura desplegada. Referencias: RNF-01 a RNF-09, ADR-001, C4 L2, integridad financiera y auditoría

1. Selección explícita del borde

Opción base: Amazon API Gateway HTTP API con integración privada VPC Link -> Application Load Balancer interno -> servicios ECS Fargate. Esta elección evita dejar abierta la combinación de REST/HTTP API y ALB/NLB. Debe verificarse en cuenta y región objetivo, incluidas cuotas, autenticación y características requeridas

Canal web: CloudFront sirve la SPA; las rutas API web se envían al BFF. La SPA no almacena tokens OAuth en localStorage. El BFF mantiene sesión protegida por cookie Secure, HttpOnly y SameSite, CSRF y control de sesión. La integración del IdP requiere flujos de redirección apropiados

Canal móvil: el IdP existente ejecuta Authorization Code + PKCE; API Gateway valida JWT cuando la funcionalidad y configuración lo permiten, y los servicios validan scopes, audiencia, titularidad y autorización por recurso. No confundir validación de token con autorización bancaria completa

CloudFront: el diseño propone distribución web y API bajo dominios/rutas adecuados; verificar políticas de caché, cabeceras, cookies y forwarding. No almacenar en caché respuestas autenticadas ni datos sensibles de clientes

2. Red y zonas

Capa	Distribución	Control
Edge	CloudFront, WAF, API Gateway gestionados	TLS, WAF, throttling, políticas de cabeceras
Entrada VPC	VPC Link en subredes privadas; ALB interno	Security groups y rutas por servicio
Cómputo	ECS Fargate, tareas en al menos 2 AZ	Sin IP pública; IAM task role / execution role distintos
Datos	Aurora PostgreSQL con alta disponibilidad según configuración seleccionada	KMS, TLS, SG restrictivos, credenciales rotadas
Caché	ElastiCache Redis según perfil y Multi-AZ	TTL, TLS, no fuente de saldos
Mensajería	EventBridge/SQS/DLQ	IAM por cola, cifrado, retención y alertas
Egreso	VPC endpoints para servicios compatibles; NAT/egreso inspeccionado para terceros	Allowlists, DNS y control de costos
Conectividad Core	Enlace privado/VPN/Direct Connect según entorno BP	Redundancia de enlace, mTLS/controles compatibles con Core

Límite: dos AZ reducen falla zonal, no eliminan falla regional ni dependencia de Core, IdP o proveedores

3. Ownership y persistencia

Aurora conserva estado local transaccional, idempotencia y outbox; no el libro mayor del Core

El estado de Onboarding y la evidencia de Auditoría tienen ownership lógico separado. Esquemas, usuarios y permisos por servicio como mínimo; instancias separadas si aislamiento, carga o retención lo justifican

El repositorio de auditoría debe satisfacer append-only, protección frente a modificaciones, consulta segregada y retención legal. No afirmar WORM hasta seleccionar y probar el mecanismo

El relay Outbox se ejecuta como worker independiente; la cola entrega al menos una vez y los consumidores deduplican

4. Seguridad por capas

1. Edge: AWS WAF, controles de abuso, TLS, protección de rutas y políticas de tasa

2. Identidad: OIDC, PKCE móvil, sesiones BFF web, JWT con issuer/audience/exp; step-up en operaciones sensibles

3. Servicios: autorización por cuenta, roles, límites y políticas; no confiar en el frontend

4. Red: servicios privados, grupos de seguridad restrictivos, segmentación de rutas, endpoints privados

5. Datos: KMS, TLS, rotación de secretos, minimización de PII y segregación de permisos

6. Operación: CloudTrail para actividad AWS, logs de aplicación sin secretos, evidencias de auditoría de negocio en sistema propio

CloudTrail no reemplaza la auditoría de acciones del cliente. La residencia de datos y obligaciones de LOPDP deben ser verificadas antes de elegir región o política de replicación

5. Despliegue y rollback

Pipeline propuesto: lint/tests -> análisis SAST/dependencias/secretos -> build reproducible -> escaneo de imagen -> push a ECR -> deploy gradual ECS -> health checks -> smoke/contratos -> promoción o rollback. Las migraciones de base de datos deben ser compatibles hacia atrás (expand/contract). Una reversión de imagen no revierte automáticamente cambios de esquema ni operaciones bancarias confirmadas

6. Riesgos y decisiones abiertas

Riesgo	Mitigación / decisión
HTTP API no cubre una característica requerida	Evaluar REST API y compatibilidad de integración privada antes de cerrar contrato
ALB/servicio no saludable	Health checks, tareas en varias AZ, alarmas y rollback
Core lento o caído	Timeout, bulkhead, circuit breaker; no inventar histórico ni reenviar débito ambiguo
Pérdida de Aurora	Failover probado, backups y restauración; conexión/retry segura
Cola/DLQ saturada	Alarma por edad, profundidad, reintentos y redrive controlado
Auditoría no disponible	Política por acción; evidencia durable o fail-closed antes de operaciones críticas
Egreso y NAT costosos	Endpoints privados y evaluación por GB/solicitudes
Región no autorizada	Revisar residencia y contrato antes de provisionar

7. Artefactos

Topología AWS

Operación y recuperación

Runbooks y observabilidad

Capacidad y costos

Nota: los diagramas son vistas de infraestructura complementarias al workspace C4 Structurizr; no se crean nuevos contenedores de negocio por el hecho de desplegarlos en múltiples AZ

8. Vista iconográfica y dependencias de seguridad

Topología AWS en SVG autocontenido

Operación y recuperación en SVG autocontenido

Los diagramas representan los servicios AWS y sus dependencias lógicas; su iconografía es ilustrativa y no implica un despliegue existente

Seguridad ampliada: el proveedor antifraude externo y el gateway MX son dependencias de integración sujetas a contrato, conectividad controlada, autenticación mutua cuando aplique, políticas de egress, minimización de datos, alertas y pruebas de resiliencia. Consultar riesgos, ADR-008 y ADR-009

9. Integración Core con Camel y continuidad

El ADR-010 propone Camel embebido en adaptador Spring Boot ECS Fargate, sin broker adicional por defecto. Si el Core requiere SOAP/MQ/formatos legacy, la selección de componente y topología depende del contrato. Ver matriz de fallos AWS-01..08. No existe validación de despliegue ni de RTO/RPO medidos

Operación y observabilidad

Estado: propuesta operativa. Umbrales iniciales para revisión, no resultados medidos

1. Objetivos de servicio

SLI	Definición propuesta	Objetivo inicial	Fuente
Disponibilidad canal	Solicitudes válidas exitosas / solicitudes elegibles	99.95% mensual (hipótesis)	API Gateway + ALB + trazas
Latencia consultas	p95 del tramo BP sin Core externo	<=500 ms (hipótesis)	OpenTelemetry
Integridad financiera	Operaciones confirmadas sin doble ejecución lógica	100% para pruebas de idempotencia	BD local + Core/conciliación
Publicación eventos	Edad máxima de outbox no publicado	Alerta si >5 min (umbral propuesto)	Métrica worker
Cola	Edad de mensaje más antiguo / DLQ	Alerta si >5 min o DLQ >0 (propuesta)	SQS/CloudWatch
Auditoría	Eventos esperados sin evidencia durable	0 brechas sin investigar	Reconciliación
Conciliación	Operaciones ambiguas abiertas	Alerta si >15 min (propuesta)	Métrica de dominio

Cálculo: 99.95% equivale a ~21.6 minutos de indisponibilidad permitida en 30 días; no incluye automáticamente el SLA de Core ni terceros. Las dependencias externas deben tener SLI diferenciados

2. Observabilidad y privacidad

Propagar traceparent, correlationId, operationId (referencia opaca) desde BFF hasta adaptadores y workers

OpenTelemetry para trazas; CloudWatch para métricas y logs estructurados. Instrumentar RED (rate/errors/duration), saturación, pool JDBC, throttling, estado de tareas ECS, Aurora, Redis, SQS, outbox y conciliación

Nunca registrar JWT, secretos, plantillas biométricas, cuentas completas ni payload financiero sensible

Distinguir errores 4xx de negocio de errores 5xx y timeouts de dependencias; no calcular disponibilidad solo desde 5xx

Alarmas por severidad, deduplicación de alertas y vinculación a runbooks

3. Runbooks

OPS-01 — ECS / ALB degradado

Detección: health checks fallidos, 5xx o tareas por debajo del mínimo. Diagnóstico: despliegue reciente, errores, límites CPU/memoria, targets ALB, cuotas. Mitigación: rollback del despliegue, reemplazo de tareas, aumento controlado de capacidad. Cierre: smoke tests y métricas recuperadas. No cambiar esquemas a ciegas

OPS-02 — Aurora failover o saturación

Detección: conexiones, latencia SQL, failover y errores. Diagnóstico: estado de clúster, pool de conexiones, locks, IOPS. Mitigación: retry acotado solo en operaciones locales idempotentes, reconexión, throttling, escalar si procede. Cierre: validar estado local, outbox e idempotencia. Nunca repetir una orden remota ambigua

OPS-03 — Outbox / SQS / DLQ

Detección: edad outbox, mensajes visibles, edad máxima, DLQ. Diagnóstico: fallo de relay, permisos, cuota, esquema o consumidor. Mitigación: recuperar worker, corregir contrato, redrive controlado tras identificar causa; consumidores idempotentes. Cierre: conciliar eventId, cantidad de eventos y estados

OPS-04 — Core / pagos indisponible

Detección: timeouts, circuit breaker abierto, operaciones PENDING_RECONCILIATION. Diagnóstico: red, credenciales, capacidad y referencia remota. Mitigación: detener reintentos inseguros, consultar estado por referencia, escalar a operación bancaria. Cierre: conciliación con evidencia externa, sin doble débito

OPS-05 — Auditoría degradada

Detección: fallos de ingesta, backlog o discrepancias. Mitigación: fail-closed previo a acción crítica o buffer durable aprobado para acciones permitidas; preservar eventos financieros locales. Cierre: reconciliación de brechas y aprobación del responsable de seguridad

OPS-06 — Desastre regional

Detección: indisponibilidad regional declarada según criterios de continuidad. Mitigación: declarar incidente, suspender comandos financieros inseguros, restaurar copias autorizadas en región secundaria, verificar secretos, red, datos y reconciliación con Core. Cierre: smoke tests, validación de integridad, aprobación de negocio y reapertura controlada. No asumir conmutación automática

4. Pruebas y evidencia esperada

ID	Ejercicio	Aceptación
AWS-01	Interrumpir tareas en AZ-A	Tráfico atendido en AZ-B, sin pérdida de operaciones
AWS-02	Failover Aurora	Recuperación de conexiones y estado sin duplicación
AWS-03	Cortar acceso a Core tras envío	Estado incierto y conciliación, no nuevo débito
AWS-04	Detener Outbox Relay	Backlog durable y publicación tras recuperación
AWS-05	Deshabilitar auditoría	Política de falla aplicada y evidencia conservada
AWS-06	Restaurar backup en entorno aislado	Integridad de datos y medición RTO/RPO
AWS-07	Saturar servicios y colas	Escalado acotado, alarmas y protección Core
AWS-08	Rollback de versión	Compatibilidad de contratos y esquema

Ninguna prueba AWS-01 a AWS-08 se declara ejecutada

Capacidad y costos

Estado: modelo paramétrico, sin cotización AWS vigente. No atribuir supuestos a BP. Moneda: USD; elegir región y precios oficiales antes de declarar un total

1. Hipótesis iniciales

Usuarios registrados: 100,000; activos diarios: 10,000

Pico: 100 RPS de consultas y 10 TPS financieros

Base: 2 AZ, mínimo 2 tareas por servicio crítico; 730 horas/mes para costos fijos

Factores de escenario: bajo 0.5x, base 1x, alto 3x de carga; la base HA no escala linealmente hacia abajo

Supuestos faltantes: perfil horario, sesiones concurrentes, tamaño de payload, GB egress, GB de logs/trazas, conexiones Core, IOPS/GB Aurora, retención y costo de enlaces privados

2. Modelo de demanda

RPS_promedio = operaciones_mensuales / (30 24 3600)

concurrencia_en_vuelo ≈ RPS_pico * latencia_segundos (Ley de Little; solo aproximación bajo régimen estable)

tareas_requeridas = ceil(RPS_pico / capacidad_sostenida_por_tarea), con piso de 2 tareas en AZ distintas para servicios críticos. La capacidad por tarea se mide en pruebas de carga con latencia p95, memoria, CPU y límites del Core; no se inventa

Ejemplo ilustrativo: 100 RPS y 0.5 s implican ~50 solicitudes simultáneas en vuelo. Esto no equivale a 50 usuarios concurrentes ni define por sí solo el tamaño Fargate

3. Fórmula mensual de costo

C_total = C_Fargate + C_ALB + C_API_Gateway + C_CloudFront + C_WAF + C_Aurora + C_Redis + C_EventBridge + C_SQS + C_NAT + C_VPC_endpoints + C_egress + C_CloudWatch + C_KMS + C_Secrets + C_backups + C_DR + contingencia

Componente	Unidad para cotizar	Sensibilidad
ECS Fargate	vCPU-h y GB-h por tarea	Cantidad de servicios, tareas y escalado
ALB	Horas + LCU	Conexiones, bytes, reglas
API Gateway HTTP API	Solicitudes y transferencia aplicable	RPS y tamaño
CloudFront / WAF	Requests, GB, reglas	Tráfico y seguridad
Aurora	Instancias, almacenamiento, I/O, backups	Consultas, escritura, réplicas
Redis	Tipo y número de nodos / capacidad	Cache hit y HA
EventBridge / SQS	Eventos y solicitudes	Fanout, retries, DLQ
NAT / endpoints	Horas, GB y endpoints	Egreso y número de AZ
CloudWatch / OTel	GB ingesta, métricas, trazas y retención	Muestreo y logging

Componente	Unidad para cotizar	Sensibilidad
KMS / Secrets	Claves, operaciones, secretos	Cifrado y rotación
Backups / DR	GB almacenados y transferidos	RPO/RTO y residencia

4. Escenarios y validación

Escenario	Demanda	Capacidad mínima	Costo
Bajo	50 RPS + 5 TPS	HA en 2 AZ	Por cotizar
Base	100 RPS + 10 TPS	HA en 2 AZ	Por cotizar
Alto	300 RPS + 30 TPS	Escalado y cuota Core a validar	Por cotizar

Para cada escenario, ejecutar pruebas de carga y obtener tarifa de AWS Pricing Calculator en la misma región. Separar costo de desarrollo/pruebas, producción y DR; incluir transferencias inter-AZ y costos de conectividad Core

5. Trade-offs y control

Fargate vs EKS: menor carga operativa inicial frente a control avanzado de plataforma

Aurora vs RDS PostgreSQL: comparar costo/IO/HA reales; no asumir que Aurora siempre es más barato

HTTP API vs REST API: verificar funcionalidades y costo por solicitud

Endpoints privados vs NAT: comparar horas/GB, seguridad y disponibilidad

DR backups vs warm standby: costo bajo con recuperación más lenta frente a mayor gasto y menor RTO potencial

AWS Budgets, Cost Anomaly Detection, etiquetas por dominio y alarmas de consumo

Pendientes: región permitida, precios a fecha de cotización, benchmarks, presupuesto objetivo y estrategia de continuidad aprobada. No se calculan cifras monetarias sin estos insumos

Presupuesto AWS ilustrativo — desglose y supuestos

Estado: estimación de planificación acordada en revisiones editoriales previas; no es una cotización AWS ni un presupuesto aprobado por BP. Se recupera aquí para evitar pérdida de decisiones documentales

Hipótesis y alcance

Región principal: us-east-1; backups regionales: us-west-2

100.000 usuarios registrados y 10.000 usuarios activos diarios (hipótesis)

Pico de 100 RPS de consultas y 10 TPS financieros, no medidos

Seis servicios de dominio, dos tareas ECS Fargate por servicio: 12 tareas distribuidas en dos AZ

730 horas mensuales. Dos nodos Aurora PostgreSQL y dos nodos Redis en el ejemplo

DR mediante respaldos cross-region; warm standby / DR activo no incluido

Tarifas unitarias ficticias para ejercicio de modelación, no verificadas en AWS Pricing Calculator

Desglose mensual en USD

Componente	Cantidad / cálculo	Tarifa hipotética	Subtotal USD
			:
ECS Fargate	12 tareas × 730 h	0,060 USD/tarea-h	525,60
Aurora PostgreSQL	2 nodos × 730 h	0,450 USD/nodo-h	657,00
Aurora almacenamiento / I/O	Paquete mensual de ejemplo	250 USD/mes	250,00
ElastiCache Redis	2 nodos × 730 h	0,140 USD/nodo-h	204,40
ALB interno	730 h + LCU	95 USD/mes	95,00
API Gateway	Solicitudes mensuales	80 USD/mes	80,00
CloudFront + WAF + S3	Distribución, reglas y origen	175 USD/mes	175,00
EventBridge + SQS + DLQ	Eventos y solicitudes	65 USD/mes	65,00
CloudWatch / trazas / logs	Ingesta, métricas y retención	190 USD/mes	190,00
KMS + Secrets Manager	Claves, solicitudes y secretos	45 USD/mes	45,00
NAT / VPC endpoints	Horas y GB de transferencia	240 USD/mes	240,00
Backup primario y cross-region	Copias, GB y transferencias	160 USD/mes	160,00
Conectividad Core / egreso	Enlace y tráfico estimados	180 USD/mes	180,00
SUBTOTAL BASE	Sin soporte, impuestos ni DR activo		2.867,00
Contingencia	20 % del subtotal		573,40
TOTAL DE PLANIFICACIÓN	Ejemplo, no precio AWS	USD/mes	3.440,40

Sensibilidad

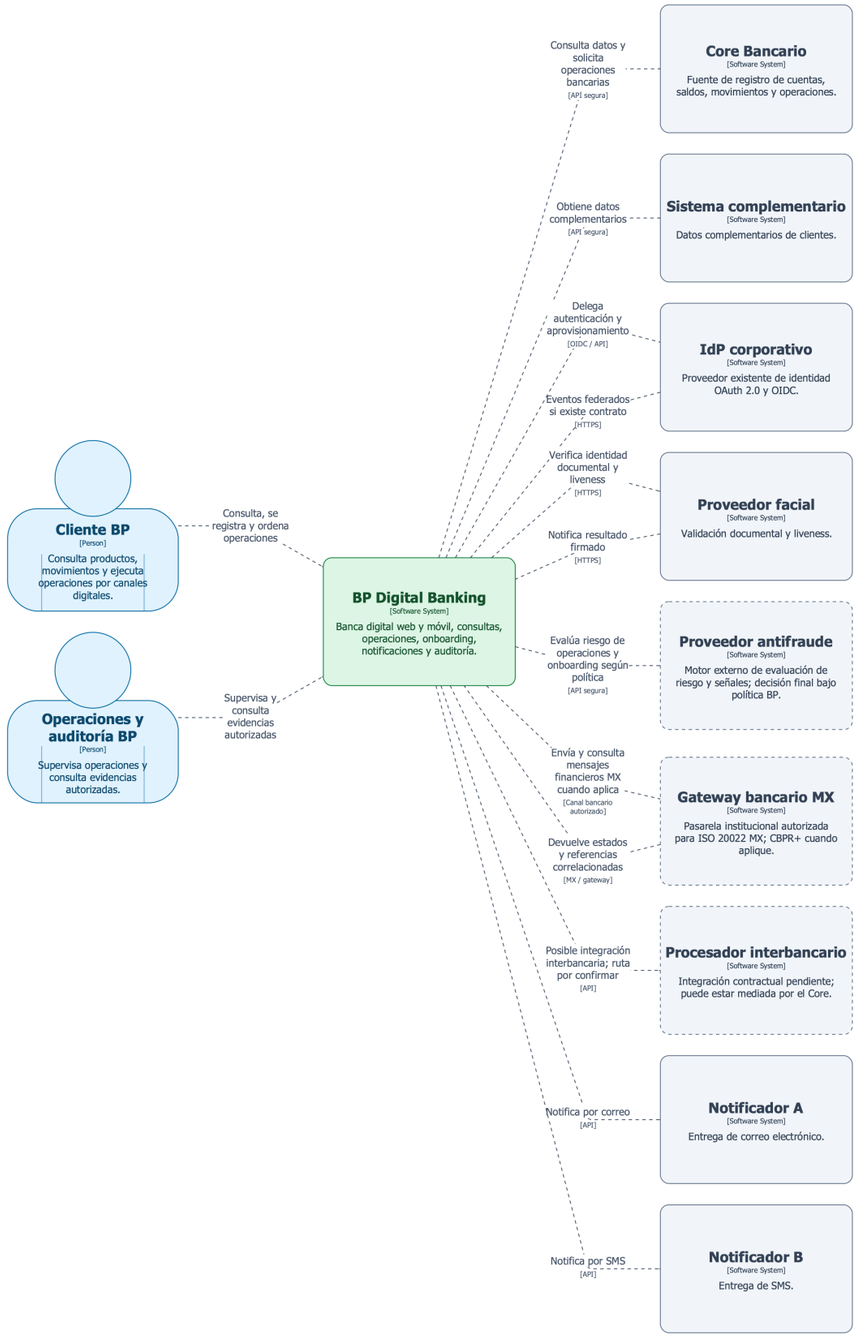
Escenario	Demanda de referencia	Interpretación
Bajo	50 RPS / 5 TPS	Conservar mínimo HA; no dividir el presupuesto entre dos
Base	100 RPS / 10 TPS	3.440,40 USD/mes, exclusivamente ilustrativo
Alto	300 RPS / 30 TPS	Requiere benchmarking y cotización; no multiplicar el costo linealmente
DR backup/restore	Copias a us-west-2	Recuperación sujeta a tiempos de restauración
DR pilot light / warm standby	Capacidad regional parcial	Cotizar por separado

Exclusiones y criterios de revisión

No se han validado rendimiento por tarea, egress real, inter-AZ, licencias, soporte, impuestos, conectividad dedicada, cuotas de Core, descuentos ni recuperación regional activa. Sustituir las tarifas ficticias por cotizaciones oficiales para la región aprobada y por resultados de pruebas de carga antes de presentar presupuesto real

Origen editorial: tabla de costos incluida en las revisiones anteriores BP_Digital_Banking_Validacion_Trazabilidad_C4_Contratos_ADR.pdf y BP_Digital_Banking_Revision_Integral_Trazabilidad_y_ADR.pdf. El PDF definitivo debe reproducir la tabla completa sin externalizar su explicación

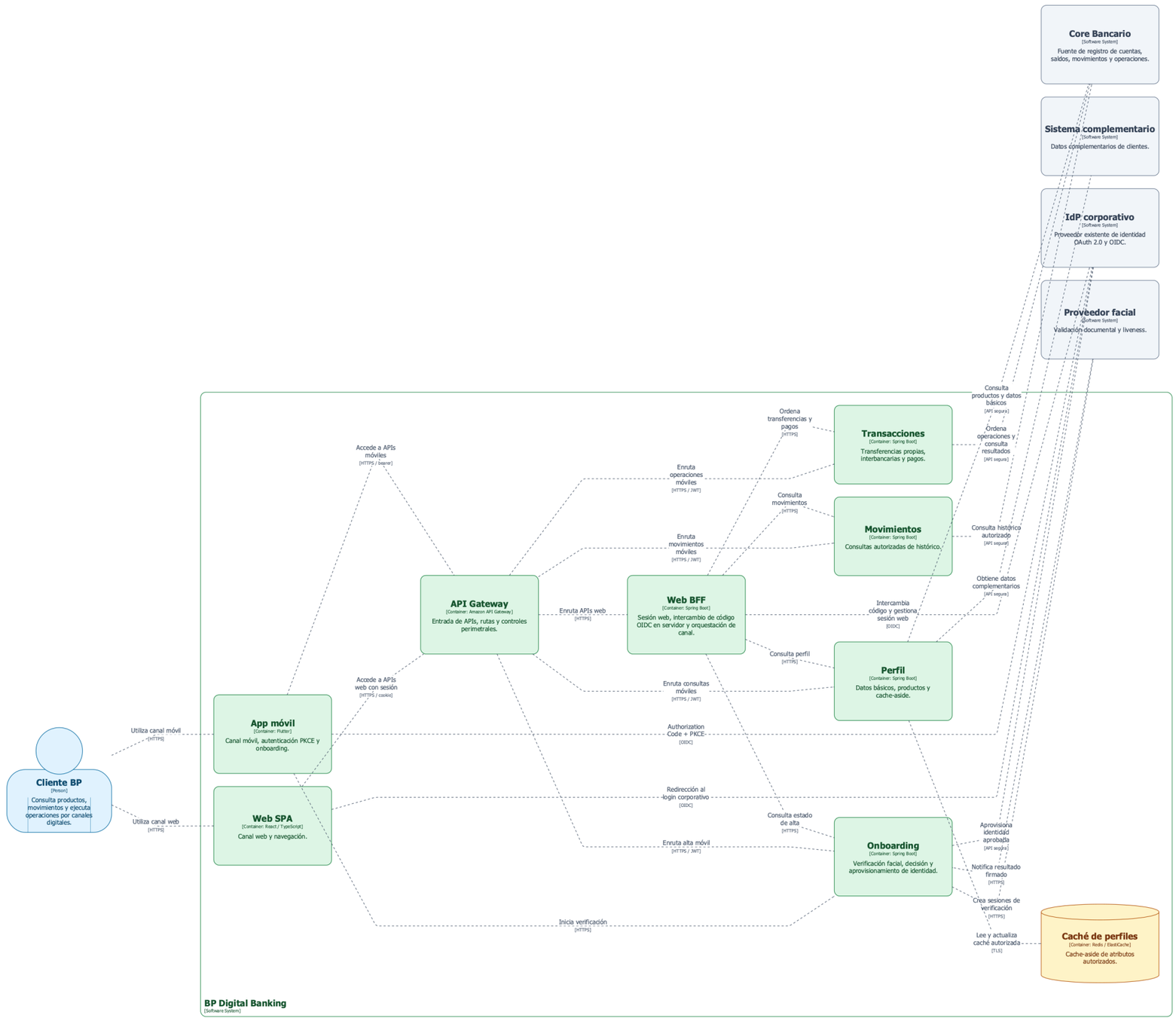
C4-01 Contexto



System Context View: BP Digital Banking
Contexto y sistemas externos
Monday, November 9, 2026 at 6:41 PM Ecuador Time

Actores, límites de BP y dependencias externas. El Core conserva la autoridad sobre los datos financieros.

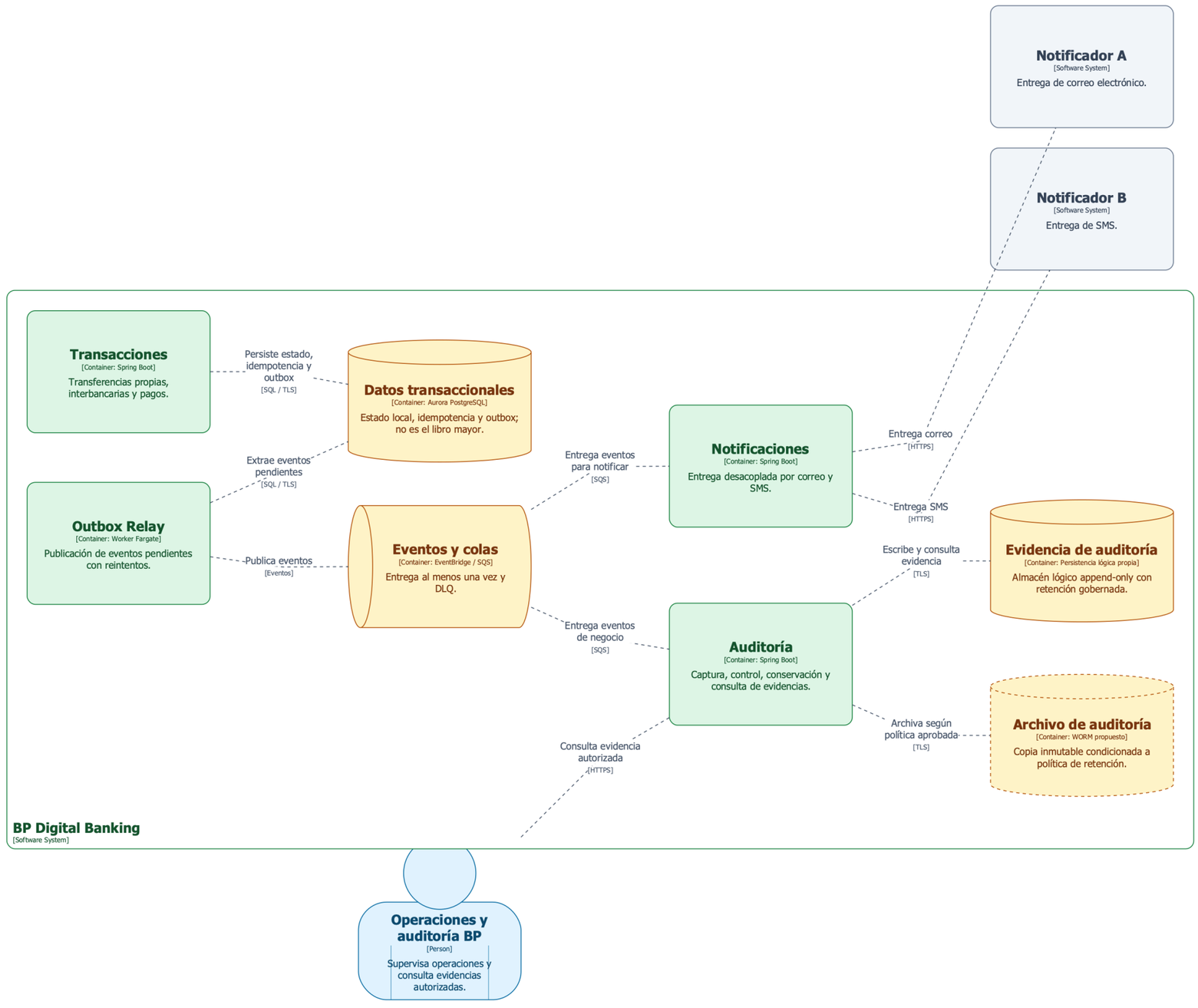
C4-02A Contenedores — cliente



Container View: BP Digital Banking
Canales, identidad y capacidades de cliente (detalle financiero en C4-03)
Monday, November 9, 2026 at 6:41 PM Ecuador Time

Canales, API, servicios de negocio y dependencias del cliente. La lectura de datos requiere autorización por titularidad.

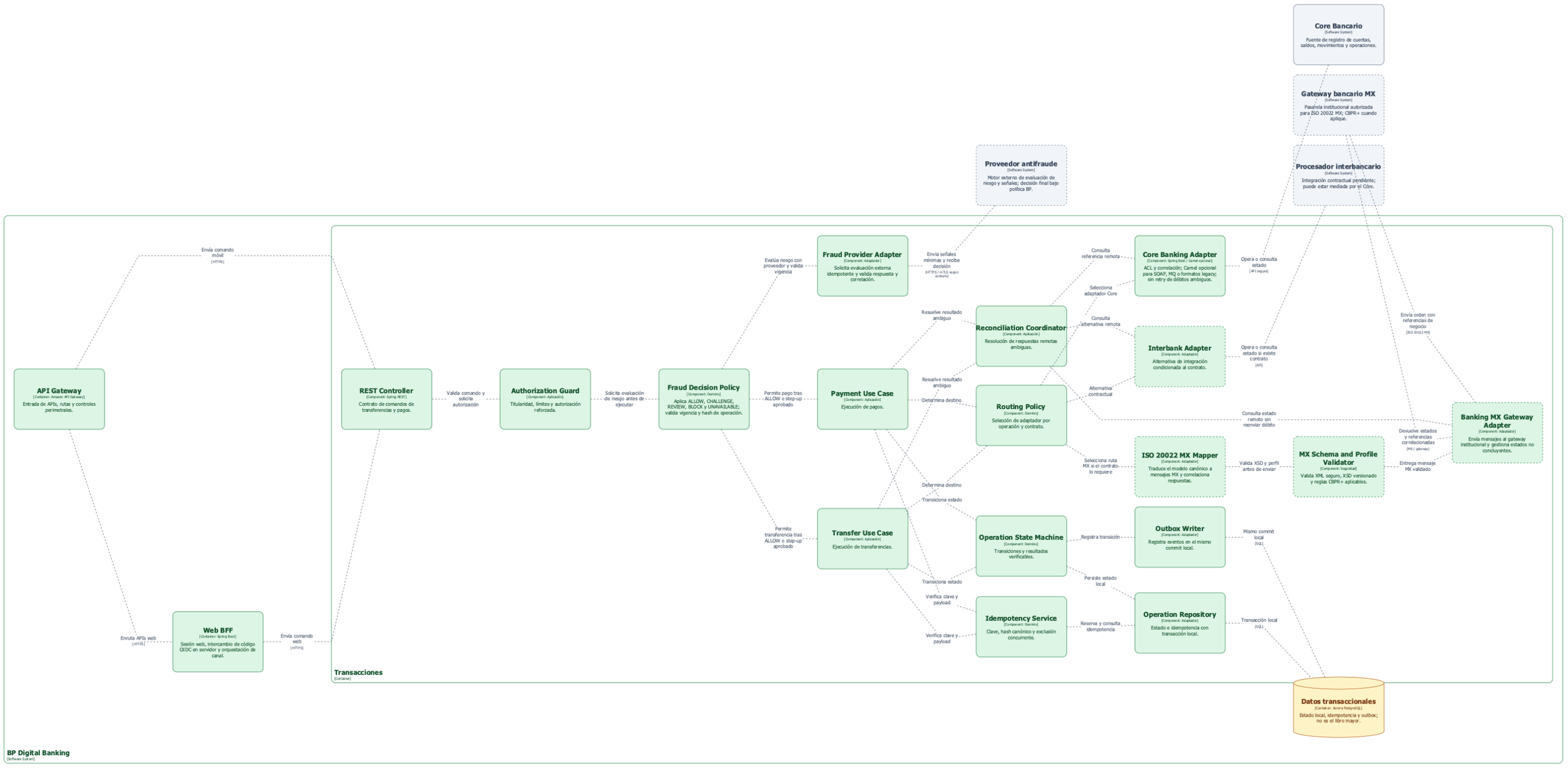
C4-02B Contenedores — operador



Container View: BP Digital Banking
Operación, eventos y auditoría (vistas complementarias)
Monday, November 9, 2026 at 6:41 PM Ecuador Time

Operación, auditoría y componentes asíncronos; se separan responsabilidades y privilegios.

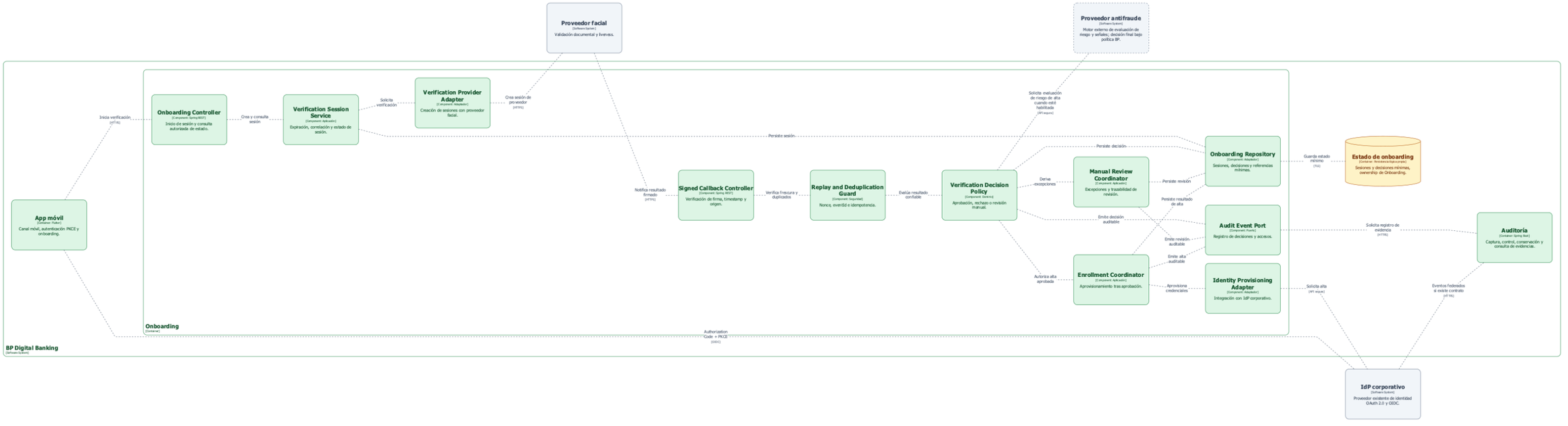
C4-03 Componentes — transacciones



Component View: BP Digital Banking - Transacciones
Componentes internos del servicio de transacciones
Monday, November 9, 2026 at 6:41 PM Ecuador Time

Idempotencia, estados, adaptadores Core, antifraude, MX condicional, outbox y conciliación.

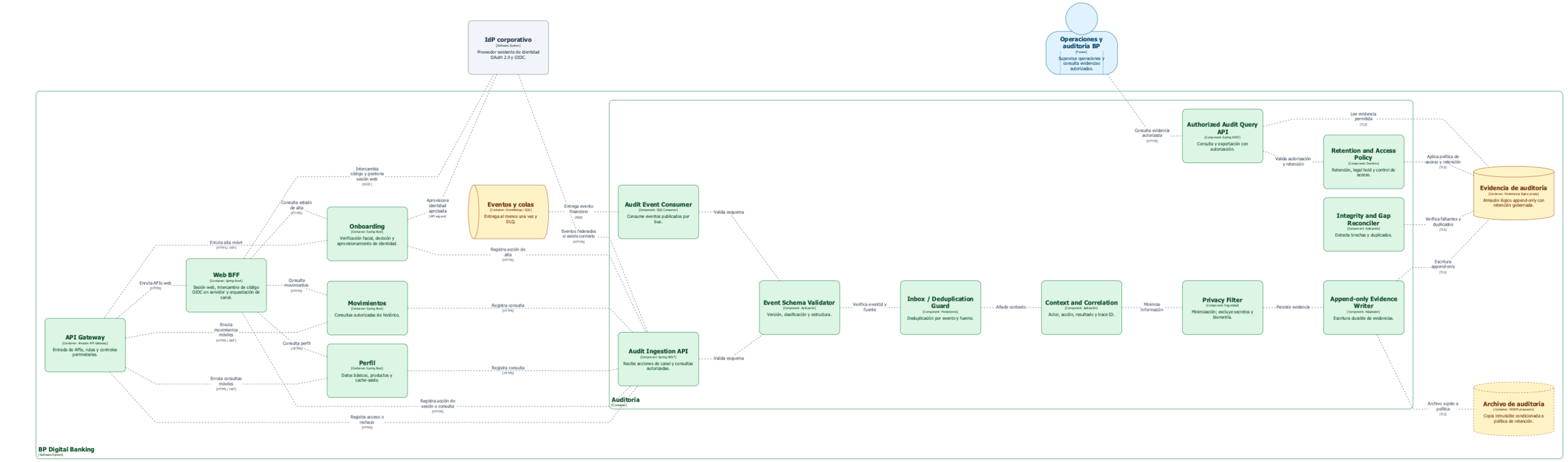
C4-04 Componentes — onboarding



Component View: BP Digital Banking - Onboarding
Componentes internos del servicio de onboarding
Monday, November 9, 2026 at 6:41 PM Ecuador Time

Verificación facial, callbacks autenticados y aprovisionamiento de credenciales mediante el IdP existente.

C4-05 Componentes — auditoría



Component View: BP Digital Banking - Auditoría
Componentes internos del servicio de auditoría
Monday, November 9, 2026 at 6:41 PM Ecuador Time

Captura y persistencia de evidencias con deduplicación y controles de privacidad.

SEQ-01 Auditoría integral

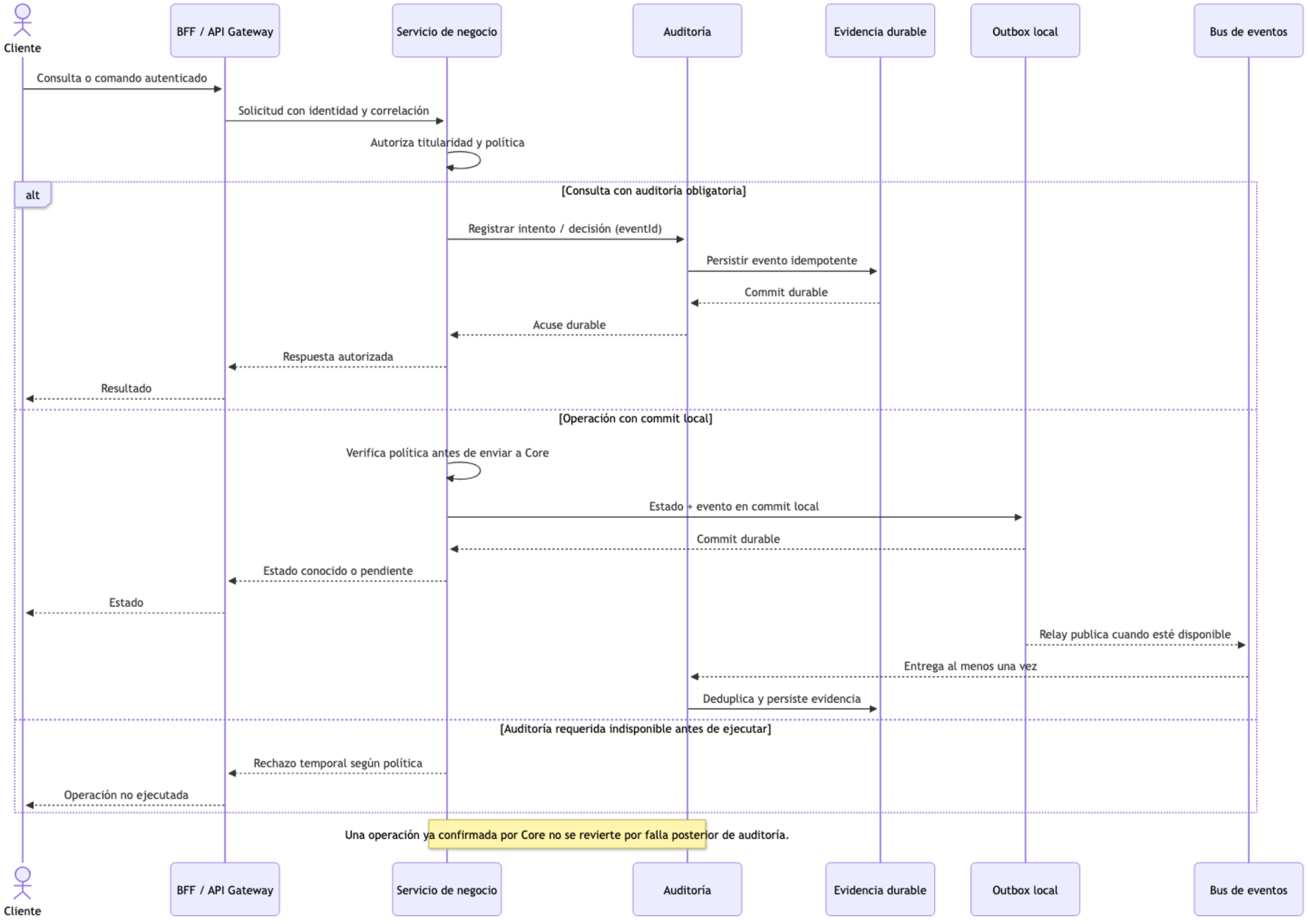


Diagrama de interacción de referencia; tiempos, contratos y dependencias reales sujetos a homologación.

SEQ-02 Pago y conciliación

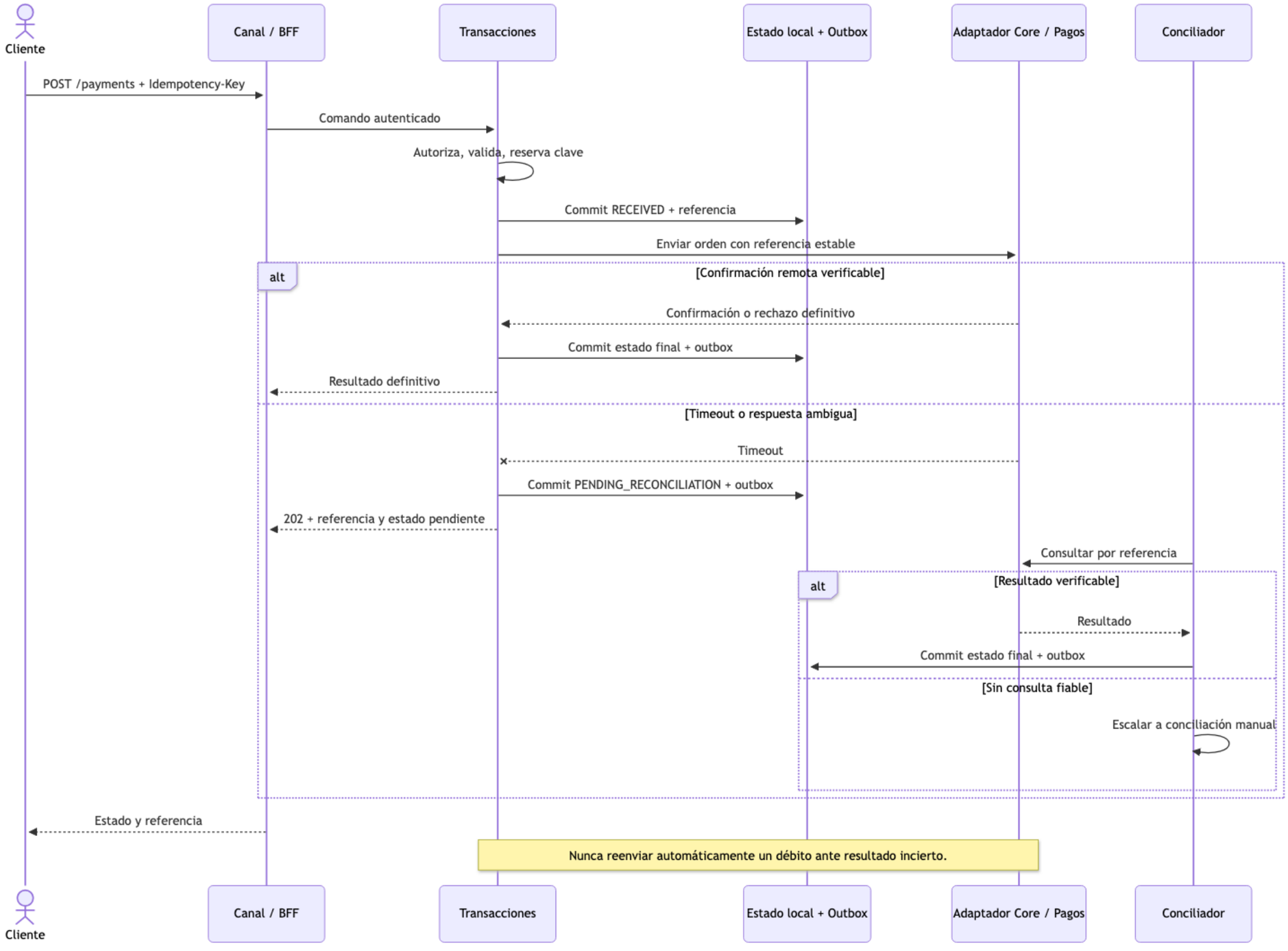


Diagrama de interacción de referencia; tiempos, contratos y dependencias reales sujetos a homologación.

SEQ-03 Antifraude y mensajería MX

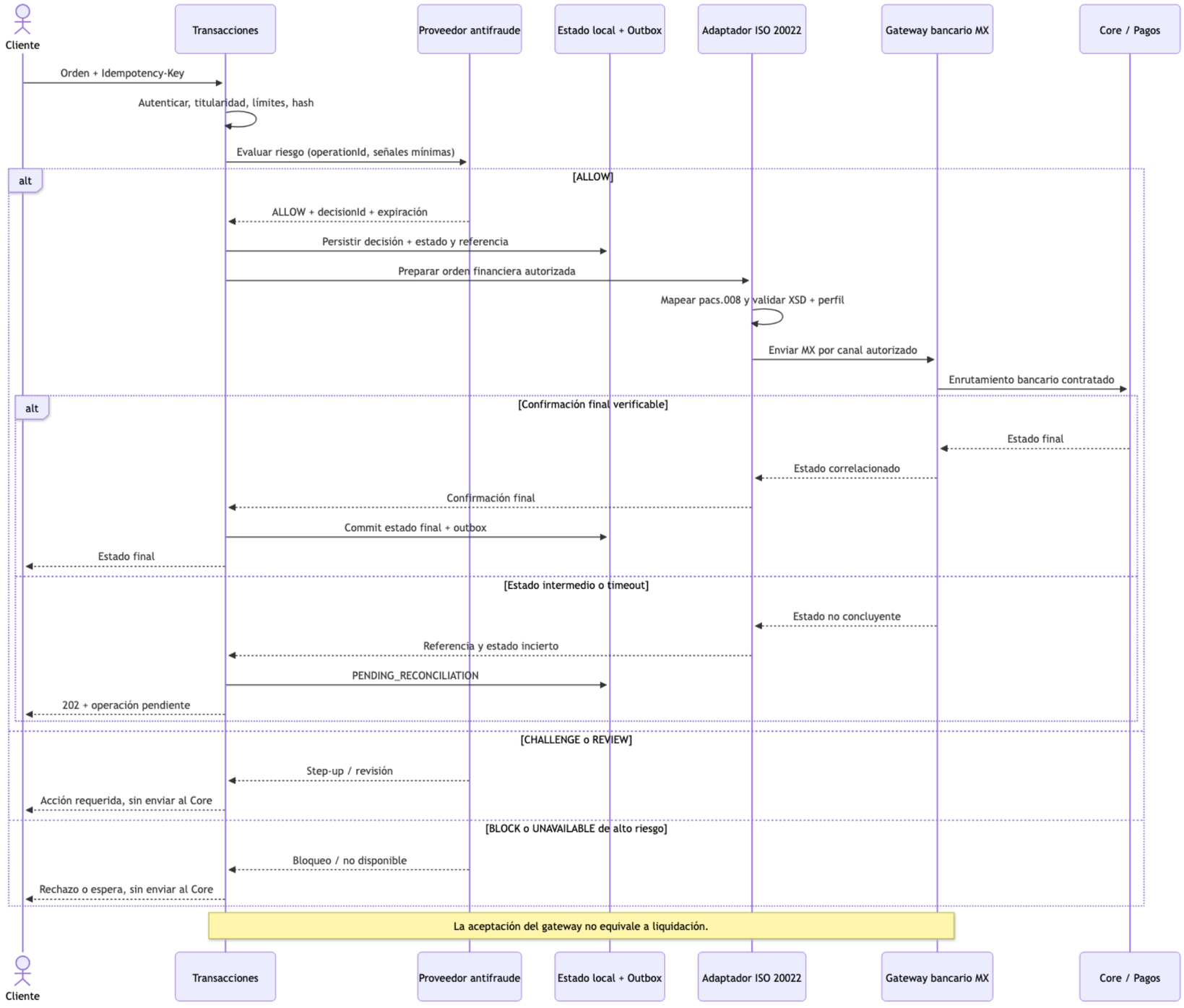


Diagrama de interacción de referencia; tiempos, contratos y dependencias reales sujetos a homologación.

SEQ-04 Autenticación OIDC

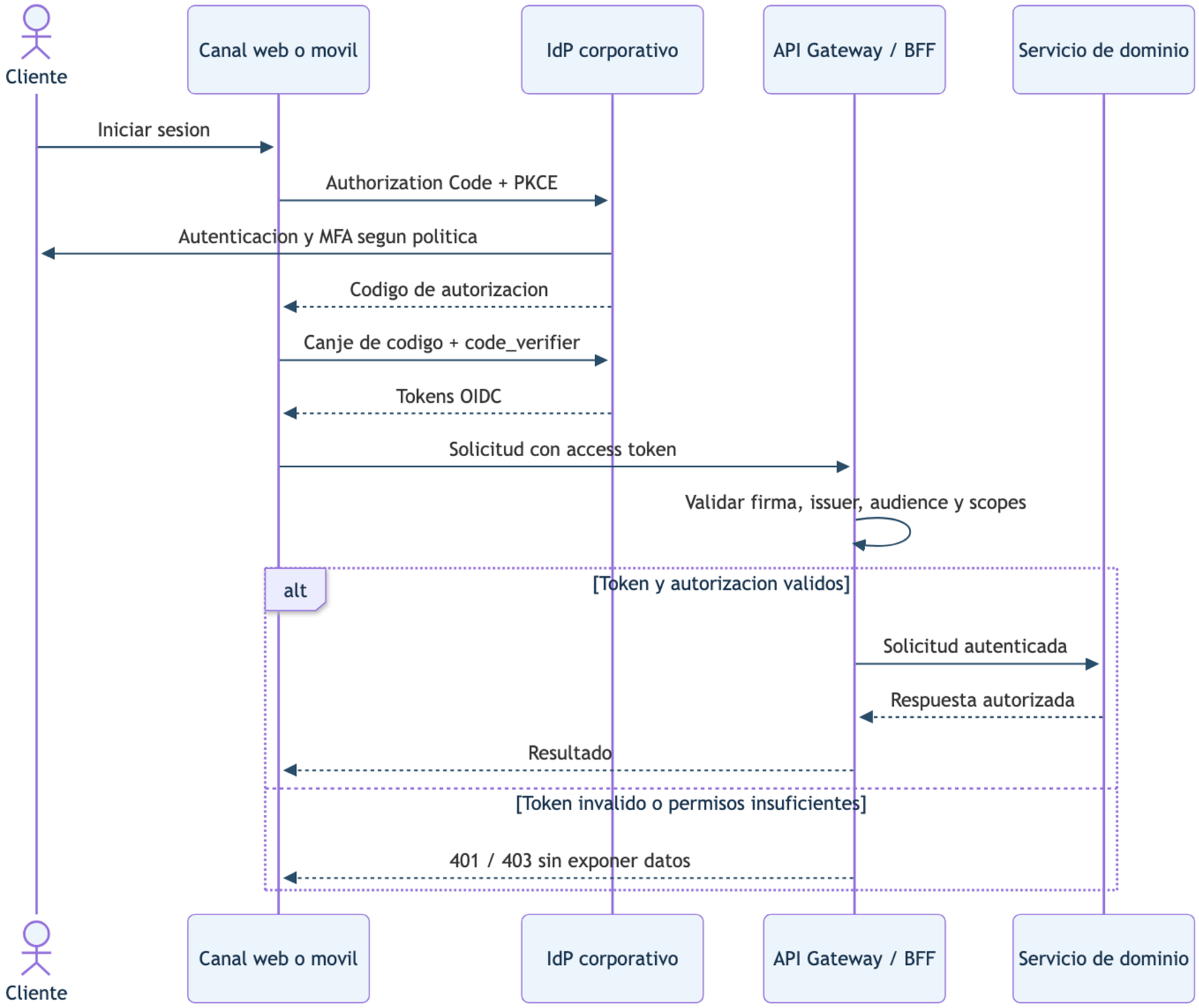


Diagrama de interacción de referencia; tiempos, contratos y dependencias reales sujetos a homologación.

SEQ-05 Onboarding facial

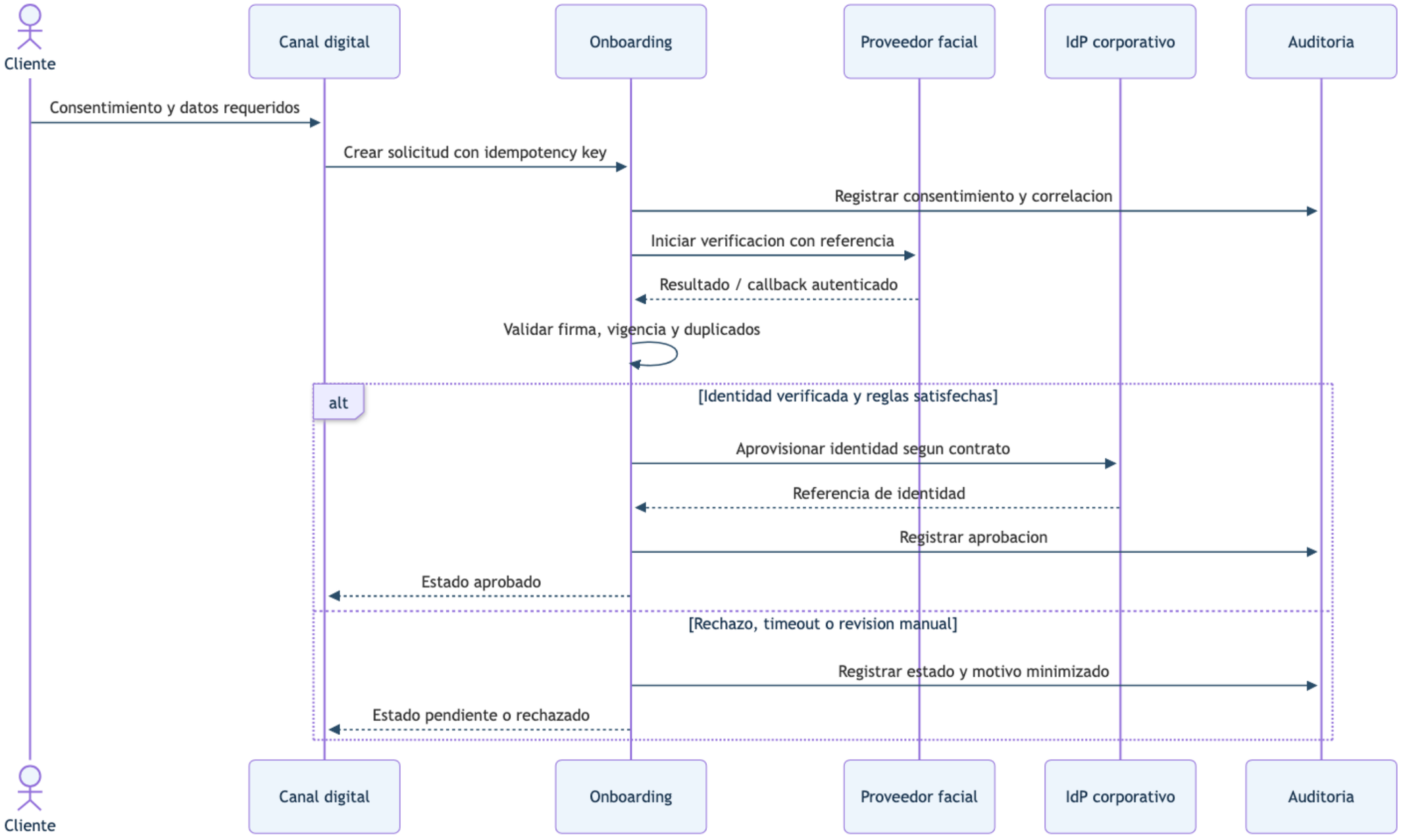


Diagrama de interacción de referencia; tiempos, contratos y dependencias reales sujetos a homologación.

SEQ-06 Consulta y caché

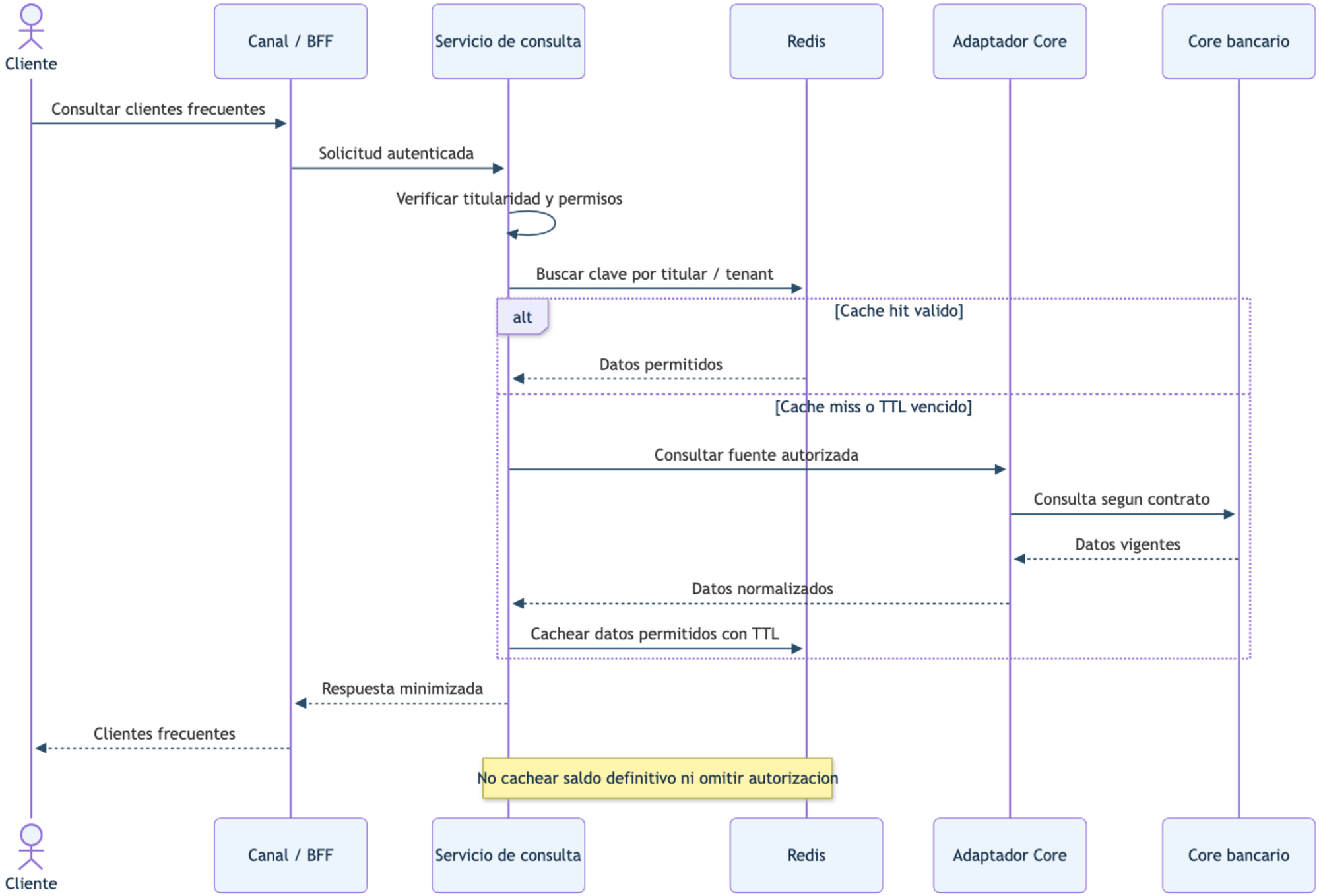


Diagrama de interacción de referencia; tiempos, contratos y dependencias reales sujetos a homologación.

SEQ-07 Notificaciones

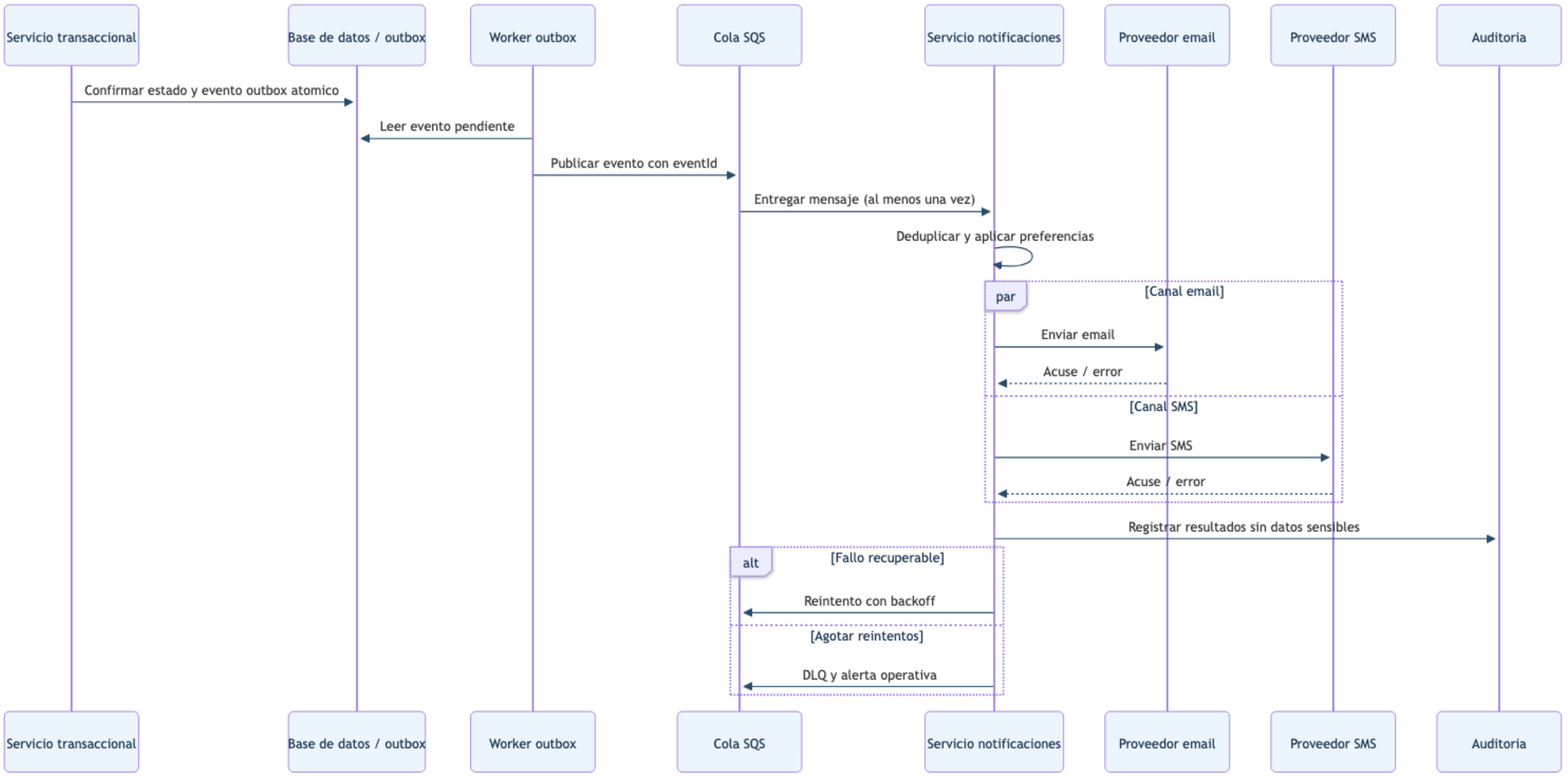


Diagrama de interacción de referencia; tiempos, contratos y dependencias reales sujetos a homologación.

SEC-01 Fronteras y controles

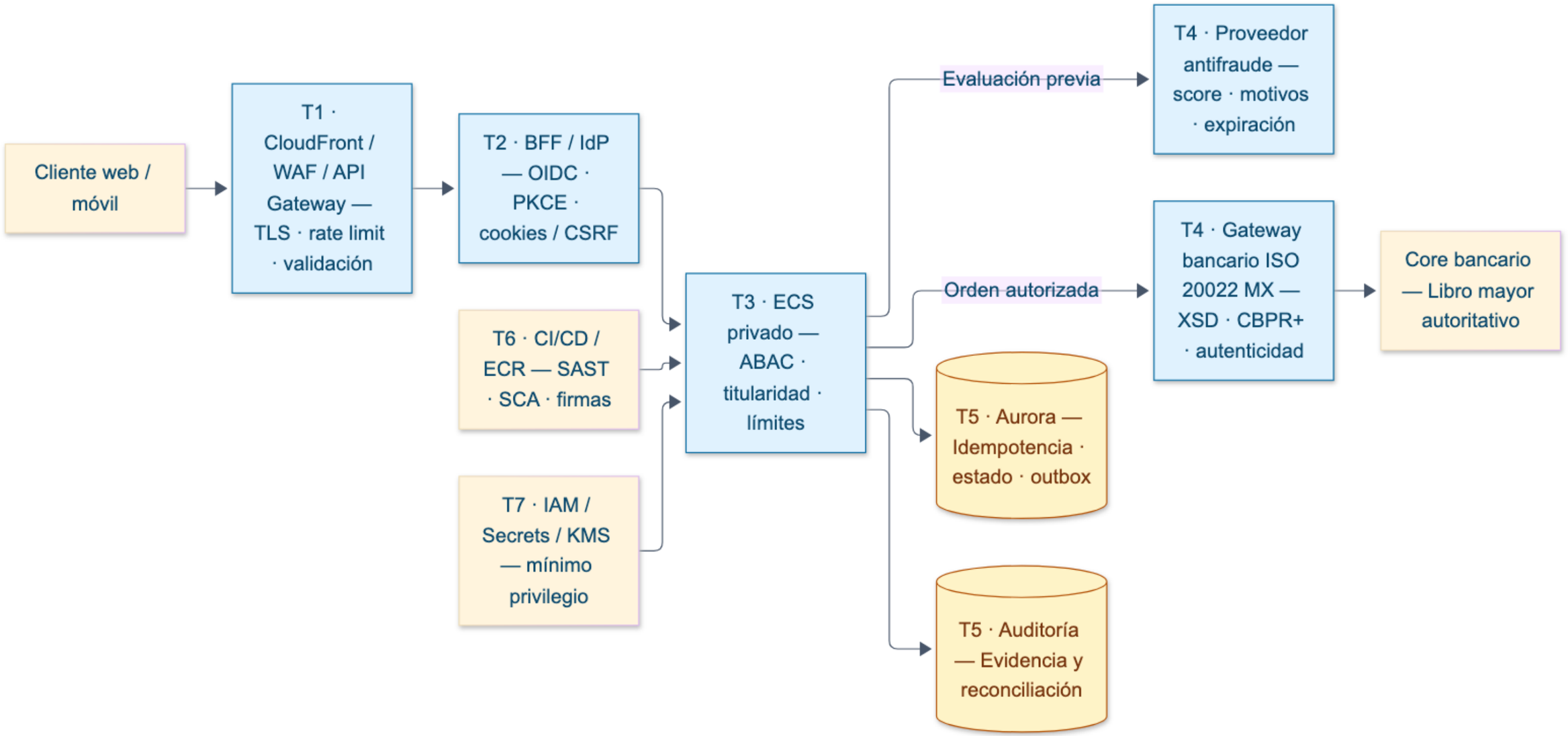
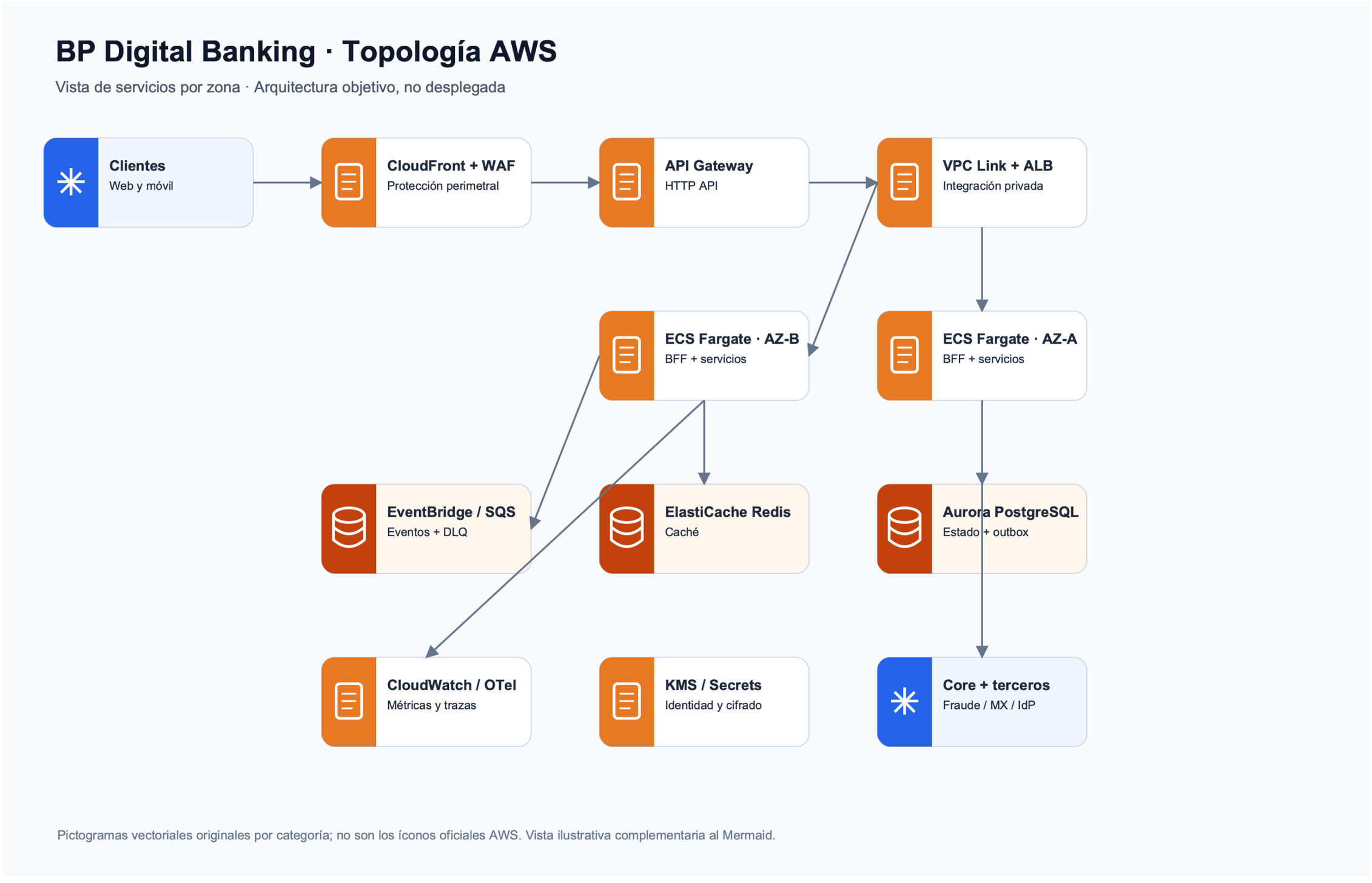


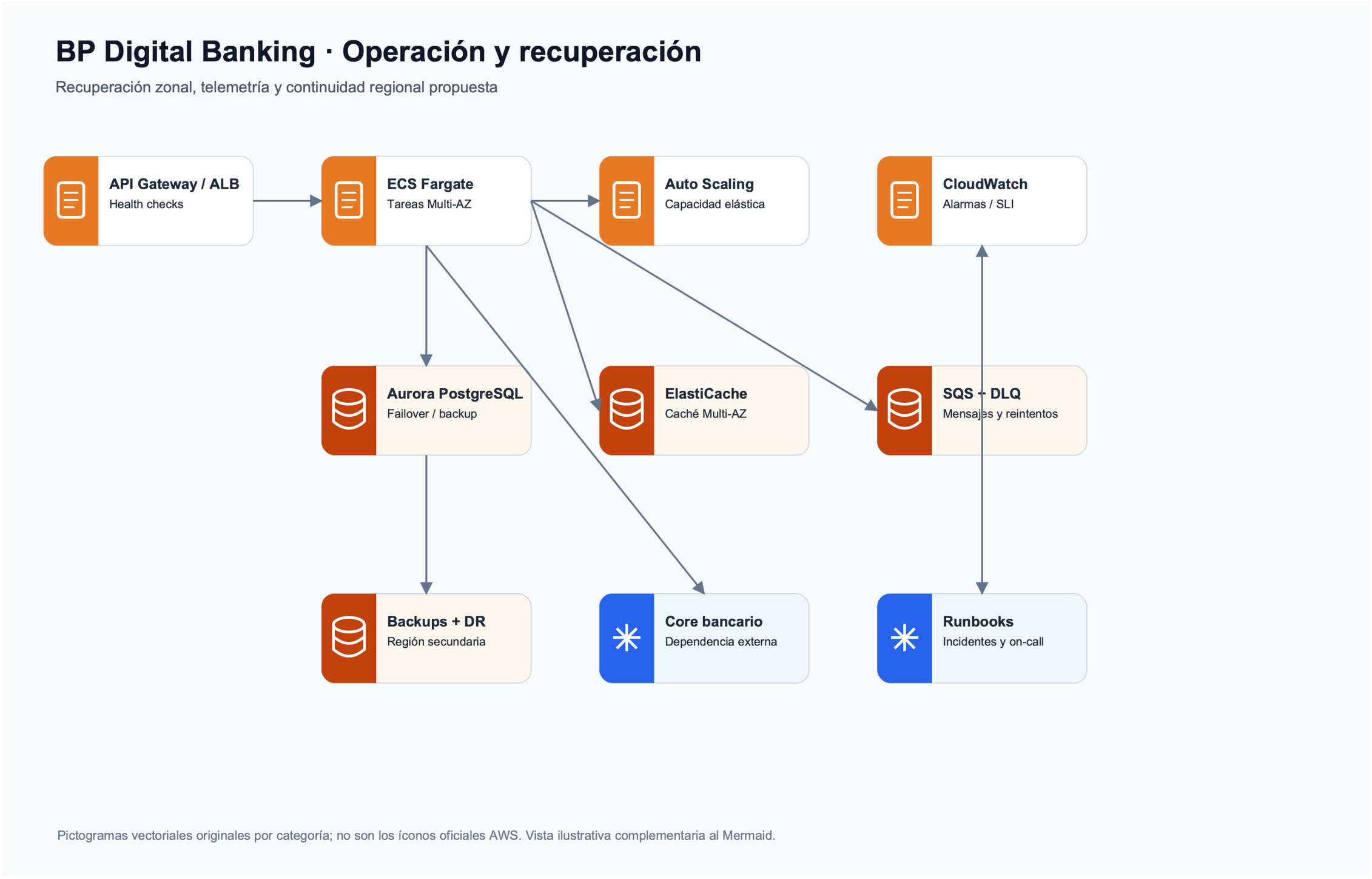
Diagrama de interacción de referencia; tiempos, contratos y dependencias reales sujetos a homologación.

AWS — topología propuesta



Topología propuesta; sin despliegue ni pruebas de recuperación productivas.

AWS — operación y recuperación



Topología propuesta; sin despliegue ni pruebas de recuperación productivas.

Decisiones arquitectónicas y alternativas

Las decisiones conservan tablas comparativas, fundamentos, consecuencias, riesgos y criterios de aceptación. Las alternativas son propuestas y requieren validación por BP.

ADR 001 cloud platform

Campo	Valor
Estado	Propuesto
Fecha	2026-11-01 (normalización documental)
Responsables	Arquitectura BP (propuesta para DEVSU)
Alcance	Plataforma cloud
Requisitos	RNF-01, RNF-02, RNF-04, RNF-05, RNF-09
Diagramas relacionados	

1. Contexto y problema

BP necesita alta disponibilidad, baja latencia, operación y recuperación sin requerir implementar el Core

2. Drivers y criterios

Seguridad bancaria, coherencia de datos, disponibilidad, latencia, mantenibilidad, integración con Core y terceros, costo total y complejidad operativa. Priorizar integridad financiera y privacidad por encima de conveniencia técnica

3. Opciones consideradas

Azure (equivalente viable si BP tiene acuerdos empresariales y capacidades internas); EKS/Kubernetes sobre AWS (más flexibilidad de orquestación, mayor costo y complejidad)

Alternativa	Ventaja	Límite	Resultado
Opción propuesta	Alineación con alcance BP y operación	Requiere validar capacidades y costos	Propuesta
Alternativas descritas arriba	Posibles ventajas de ecosistema/operación	Trade-offs adicionales	No seleccionadas por ahora

4. Decisión

AWS, CloudFront/WAF, API Gateway, ECS Fargate Multi-AZ, Aurora PostgreSQL, ElastiCache, EventBridge/SQS, CloudWatch

5. Fundamentos teóricos

1. Fundamento 1: los servicios gestionados reducen esfuerzo de parches y mantenimiento del plano de infraestructura, permitiendo enfocarse en reglas bancarias

2. Fundamento 2: las capacidades Multi-AZ, autoscaling y observabilidad facilitan diseñar recuperación y aislamiento frente a fallos de zona

6. Consecuencias y trade-offs

dependencia de servicios AWS, egresos/red, costos por solicitudes y observabilidad; requieren presupuestos, etiquetas, pruebas de resiliencia y revisión de región/residencia de datos

7. Riesgos y mitigaciones

Riesgo	Mitigación	Responsable propuesto
Dependencias externas y compatibilidad	Pruebas de contrato, revisión de SLA y fallback seguro	Arquitectura e integración
Seguridad, privacidad y costo	Threat modeling, revisión legal y FinOps	Seguridad, DPO y plataforma

8. Validación y criterios de aceptación

Revisar los diagramas relacionados contra requisitos y contratos

Comprobar supuestos técnicos con pruebas de concepto o pruebas contractuales cuando corresponda

Documentar evidencias reales; no se declara validado en esta fase

9. Supuestos, dependencias y preguntas abiertas

Confirmar SLA del Core, restricciones de residencia de datos, volumen, capacidades del IdP, topología de redes y presupuesto con BP

10. Referencias

(requisitos del reto)

11. Diseño de despliegue refinado

Se concreta como opción base API Gateway HTTP API -> VPC Link -> ALB interno -> ECS Fargate en dos AZ, con Aurora PostgreSQL, Redis, EventBridge/SQS y controles de seguridad/operación asociados. La alternativa REST API o NLB se reconsiderará si los contratos, características o restricciones de integración lo exigen. Ver topología, diseño detallado y runbooks. La decisión sigue sujeta a validación de requisitos, región, costos y pruebas de despliegue

ADR 002 channel frameworks

Campo	Valor
Estado	Propuesto
Fecha	2026-11-01 (normalización documental)
Responsables	Arquitectura BP (propuesta para DEVSU)
Alcance	Canales web y móvil
Requisitos	RF-07, RF-08, RF-09, RF-11
Diagramas relacionados	(vistas 02-contenedores-cliente y 02-contenedores-operador)

1. Contexto y problema

Elegir frameworks para SPA y app multiplataforma, preservando seguridad y mantenibilidad

2. Drivers y criterios

Seguridad bancaria, coherencia de datos, disponibilidad, latencia, mantenibilidad, integración con Core y terceros, costo total y complejidad operativa. Priorizar integridad financiera y privacidad por encima de conveniencia técnica

3. Opciones consideradas

Angular aporta convenciones y estructura empresarial más prescriptiva; React Native favorece equipos con experiencia JavaScript, pero requiere examinar dependencias nativas de SDK facial

Alternativa	Ventaja	Límite	Resultado
Opción propuesta	Alineación con alcance BP y operación	Requiere validar capacidades y costos	Propuesta
Alternativas descritas arriba	Posibles ventajas de ecosistema/operación	Trade-offs adicionales	No seleccionadas por ahora

4. Decisión

React + TypeScript para SPA; Flutter para móvil con diseño adaptativo; ambos invocan endpoints protegidos por OAuth 2.0/OIDC, Authorization Code + PKCE

Controles de seguridad asociados: sesiones de web preferentemente mediante BFF y cookies HttpOnly/Secure/SameSite, protección CSRF y política CSP; en móvil usar system browser y almacenamiento seguro de tokens, sin secretos de cliente incrustados. Biometría local no sustituye onboarding facial

5. Fundamentos teóricos

1. Fundamento 1: React favorece componentes reutilizables y separación de vistas, estado de consulta y contratos de API; TypeScript mejora verificación estática de interfaces

2. Fundamento 2: Flutter permite compartir lógica y diseño en Android/iOS con UI consistente sin exigir dos equipos nativos; integración con API nativa para biometría local y navegador del sistema

6. Consecuencias y trade-offs

disciplina de arquitectura frontend, accesibilidad, pruebas por plataforma y mantenimiento de SDKs nativos

7. Riesgos y mitigaciones

Riesgo	Mitigación	Responsable propuesto
Dependencias externas y compatibilidad	Pruebas de contrato, revisión de SLA y fallback seguro	Arquitectura e integración
Seguridad, privacidad y costo	Threat modeling, revisión legal y FinOps	Seguridad, DPO y plataforma

8. Validación y criterios de aceptación

Revisar los diagramas relacionados contra requisitos y contratos

Comprobar supuestos técnicos con pruebas de concepto o pruebas contractuales cuando corresponda

Documentar evidencias reales; no se declara validado en esta fase

9. Supuestos, dependencias y preguntas abiertas

Confirmar SLA del Core, restricciones de residencia de datos, volumen, capacidades del IdP, topología de redes y presupuesto con BP

10. Referencias

(requisitos del reto)

ADR 003 identity onboarding

Campo	Valor
Estado	Propuesto
Fecha	2026-11-01 (normalización documental)
Responsables	Arquitectura BP (propuesta para DEVSU)
Alcance	Identidad y onboarding
Requisitos	RF-09, RF-10, RF-11, RNF-03, RNF-14
Diagramas relacionados	(vista 04-componentes-onboarding); contrato INT-009 para IdP e INT-004 para verificación facial

1. Contexto y problema

Reutilizar el IdP existente y verificar identidad facial sin confundir onboarding con autenticación

2. Drivers y criterios

Seguridad bancaria, coherencia de datos, disponibilidad, latencia, mantenibilidad, integración con Core y terceros, costo total y complejidad operativa. Priorizar integridad financiera y privacidad por encima de conveniencia técnica

3. Opciones consideradas

password + MFA (disponible como fallback controlado) frente a passkeys/WebAuthn (resistente al phishing); construir un IdP nuevo se descarta porque BP ya tiene un producto configurable

Alternativa	Ventaja	Límite	Resultado
Opción propuesta	Alineación con alcance BP y operación	Requiere validar capacidades y costos	Propuesta
Alternativas descritas arriba	Posibles ventajas de ecosistema/operación	Trade-offs adicionales	No seleccionadas por ahora

4. Decisión

configurar el IdP OAuth 2.0 ya existente para soportar OIDC y flujo Authorization Code + PKCE S256 en SPA y móvil. Integrar proveedor especializado de identidad/liveness en el onboarding, antes de crear/activar credenciales. MFA adaptativa, passkeys si el IdP lo permite

5. Fundamentos teóricos

1. Fundamento 1: PKCE reduce riesgo de interceptación del código de autorización para clientes públicos, y OIDC provee identidad verificable mediante tokens con audiencia/emisor/nonce validados

2. Fundamento 2: separar prueba facial de identidad, autenticación posterior y autorización de operaciones reduce exposición de datos biométricos y facilita auditoría/regulación

6. Consecuencias y trade-offs

dependencia de capacidades del IdP, políticas de recuperación de cuenta, consentimiento/base legal y retención para datos personales sensibles, controles antifraude y revisión manual de casos ambiguos

7. Riesgos y mitigaciones

Riesgo	Mitigación	Responsable propuesto
Dependencias externas y compatibilidad	Pruebas de contrato, revisión de SLA y fallback seguro	Arquitectura e integración
Seguridad, privacidad y costo	Threat modeling, revisión legal y FinOps	Seguridad, DPO y plataforma

8. Validación y criterios de aceptación

Revisar los diagramas relacionados contra requisitos y contratos

Comprobar supuestos técnicos con pruebas de concepto o pruebas contractuales cuando corresponda

Documentar evidencias reales; no se declara validado en esta fase

9. Supuestos, dependencias y preguntas abiertas

Confirmar SLA del Core, restricciones de residencia de datos, volumen, capacidades del IdP, topología de redes y presupuesto con BP

10. Referencias

(requisitos del reto)

ADR 004 data events

Campo	Valor
Estado	Propuesto
Fecha	2026-11-01 (normalización documental)
Responsables	Arquitectura BP (propuesta para DEVSU)
Alcance	Datos, eventos y auditoría
Requisitos	RF-12, RF-13, RNF-13
Diagramas relacionados	y (vista 05-componentes-auditoria)

1. Contexto y problema

Separar persistencia autoritativa del Core, caché de lectura, evidencia de auditoría y eventos

2. Drivers y criterios

Seguridad bancaria, coherencia de datos, disponibilidad, latencia, mantenibilidad, integración con Core y terceros, costo total y complejidad operativa. Priorizar integridad financiera y privacidad por encima de conveniencia técnica

3. Opciones consideradas

Kafka/MSK para alto throughput, replay prolongado y múltiples consumidores independientes, a cambio de mayor costo/operación; caché write-through agrega acoplamiento con datos del Core; event sourcing se descarta por complejidad innecesaria

Alternativa	Ventaja	Límite	Resultado
Opción propuesta	Alineación con alcance BP y operación	Requiere validar capacidades y costos	Propuesta
Alternativas descritas arriba	Posibles ventajas de ecosistema/operación	Trade-offs adicionales	No seleccionadas por ahora

4. Decisión

Aurora PostgreSQL para datos propios del canal y estado/idempotencia de operaciones; Cache-Aside con Redis para datos frecuentes de baja sensibilidad y TTL; Transactional Outbox y EventBridge/SQS con consumidores idempotentes; auditoría crítica registrada duraderamente antes de confirmar una operación y exportada a repositorio de retención inmutable con controles de acceso

5. Fundamentos teóricos

1. Fundamento 1: Cache-Aside minimiza lecturas repetitivas al Core sin introducir una copia autoritativa de saldos y movimientos; TTL e invalidación reducen riesgo de datos obsoletos

2. Fundamento 2: Outbox evita dual write no transaccional entre estado de negocio y evento, y colas permiten reintentos/DLQ sin bloquear la operación confirmada

6. Consecuencias y trade-offs

entrega al menos una vez, orden no garantizado globalmente, diseño de claves idempotentes, reconciliación de eventos y controles de PII

7. Riesgos y mitigaciones

Riesgo	Mitigación	Responsable propuesto
Dependencias externas y compatibilidad	Pruebas de contrato, revisión de SLA y fallback seguro	Arquitectura e integración
Seguridad, privacidad y costo	Threat modeling, revisión legal y FinOps	Seguridad, DPO y plataforma

8. Validación y criterios de aceptación

Revisar los diagramas relacionados contra requisitos y contratos

Comprobar supuestos técnicos con pruebas de concepto o pruebas contractuales cuando corresponda

Documentar evidencias reales; no se declara validado en esta fase

9. Supuestos, dependencias y preguntas abiertas

Confirmar SLA del Core, restricciones de residencia de datos, volumen, capacidades del IdP, topología de redes y presupuesto con BP

10. Referencias

(requisitos del reto)

ADR 005 service boundaries

Campo	Valor
Estado	Propuesto
Fecha	2026-11-01 (normalización documental)
Responsables	Arquitectura BP (propuesta para DEVSU)
Alcance	Límites de servicios
Requisitos	RF-01 a RF-06, RF-14, RNF-07
Diagramas relacionados	(vista 03-componentes-transacciones)

1. Contexto y problema

Definir capacidades cohesivas con interfaces desacopladas de sistemas legados

2. Drivers y criterios

Seguridad bancaria, coherencia de datos, disponibilidad, latencia, mantenibilidad, integración con Core y terceros, costo total y complejidad operativa. Priorizar integridad financiera y privacidad por encima de conveniencia técnica

3. Opciones consideradas

monolito modular facilita una etapa inicial y reduce costos distribuidos; microservicio por endpoint se descarta por baja cohesión y complejidad operativa

Alternativa	Ventaja	Límite	Resultado
Opción propuesta	Alineación con alcance BP y operación	Requiere validar capacidades y costos	Propuesta
Alternativas descritas arriba	Posibles ventajas de ecosistema/operación	Trade-offs adicionales	No seleccionadas por ahora

4. Decisión

separar consultas de perfil/movimientos, transferencias/pagos, onboarding, notificaciones y auditoría, con puertos/adaptadores hacia Core y externos. Los límites se podrán revisar con métricas de carga y evolución del negocio

5. Fundamentos teóricos

1. Fundamento 1: los límites alineados a capacidades bancarias concentran reglas de negocio y facilitan evolución sin compartir acceso directo a datos privados de otros servicios

2. Fundamento 2: adaptadores anticorrupción aíslan contratos legados y reducen el impacto de modificaciones del Core o red interbancaria

6. Consecuencias y trade-offs

gobierno de contratos, tracing distribuido, consistencia eventual para proyecciones y operaciones transaccionales explícitas

7. Riesgos y mitigaciones

Riesgo	Mitigación	Responsable propuesto
Dependencias externas y compatibilidad	Pruebas de contrato, revisión de SLA y fallback seguro	Arquitectura e integración
Seguridad, privacidad y costo	Threat modeling, revisión legal y FinOps	Seguridad, DPO y plataforma

8. Validación y criterios de aceptación

Revisar los diagramas relacionados contra requisitos y contratos

Comprobar supuestos técnicos con pruebas de concepto o pruebas contractuales cuando corresponda

Documentar evidencias reales; no se declara validado en esta fase

9. Supuestos, dependencias y preguntas abiertas

Confirmar SLA del Core, restricciones de residencia de datos, volumen, capacidades del IdP, topología de redes y presupuesto con BP

10. Referencias

(requisitos del reto)

ADR 006 resilience security operations

Campo	Valor
Estado	Propuesto
Fecha	2026-11-01 (normalización documental)
Responsables	Arquitectura BP (propuesta para DEVSU)
Alcance	Continuidad y operación
Requisitos	RNF-01 a RNF-08, RNF-12
Diagramas relacionados	y

1. Contexto y problema

Proteger disponibilidad, datos y operaciones frente a fallos, incidentes y errores de terceros

2. Drivers y criterios

Seguridad bancaria, coherencia de datos, disponibilidad, latencia, mantenibilidad, integración con Core y terceros, costo total y complejidad operativa. Priorizar integridad financiera y privacidad por encima de conveniencia técnica

3. Opciones consideradas

active-active multi-región ofrece continuidad superior pero agrega costo y complejidad de consistencia; active-passive con restauración se propone como base a validar. Service mesh se descarta inicialmente por sobrecarga operativa frente a controles a nivel gateway y servicio

Alternativa	Ventaja	Límite	Resultado
Opción propuesta	Alineación con alcance BP y operación	Requiere validar capacidades y costos	Propuesta
Alternativas descritas arriba	Posibles ventajas de ecosistema/operación	Trade-offs adicionales	No seleccionadas por ahora

4. Decisión

Multi-AZ con servicios stateless y reemplazo automático; resiliencia de llamadas externas mediante timeout, circuit breaker y bulkhead; observabilidad con OpenTelemetry/CloudWatch; backups cifrados y runbooks DR; defensa en profundidad y autorización por recurso

5. Fundamentos teóricos

1. Fundamento 1: aislar fallos por zona y por proveedor evita que una dependencia externa degrade indiscriminadamente toda la banca digital

2. Fundamento 2: trazas, métricas y runbooks reducen el tiempo de diagnóstico y facilitan verificar objetivos RTO/RPO, mientras el control por recurso previene accesos indebidos aunque exista un token válido

6. Consecuencias y trade-offs

pruebas de caos/restauración, gobierno de claves y secretos, límites de carga al Core y monitoreo de terceros

7. Riesgos y mitigaciones

Riesgo	Mitigación	Responsable propuesto
Dependencias externas y compatibilidad	Pruebas de contrato, revisión de SLA y fallback seguro	Arquitectura e integración
Seguridad, privacidad y costo	Threat modeling, revisión legal y FinOps	Seguridad, DPO y plataforma

8. Validación y criterios de aceptación

Revisar los diagramas relacionados contra requisitos y contratos

Comprobar supuestos técnicos con pruebas de concepto o pruebas contractuales cuando corresponda

Documentar evidencias reales; no se declara validado en esta fase

9. Supuestos, dependencias y preguntas abiertas

Confirmar SLA del Core, restricciones de residencia de datos, volumen, capacidades del IdP, topología de redes y presupuesto con BP

10. Referencias

(requisitos del reto)

ADR 007 c4 modeling toolchain

Campo	Valor
Estado	Adoptado para el modelo C4; validación de CLI y exportación pendiente
Alcance	Contexto, contenedores y componentes de BP Digital Banking
Decisión	Mantener un modelo central en
Alternativa de visualización	Exportar SVG nativo desde el modelo Structurizr; Mermaid solo para diagramas complementarios
Fuentes anteriores	Versiones antiguas retiradas del árbol; recuperables desde el historial Git

Contexto

Las seis vistas C4 describen el mismo sistema desde distintos niveles. Al mantener cada diagrama como un archivo independiente es posible introducir diferencias en nombres, ownership, protocolos y dependencias. Se requiere una fuente de verdad que permita revisar la semántica arquitectónica y generar vistas coherentes

Alternativas

Alternativa	Ventaja	Limitación
Mermaid flowchart	Previsualización sencilla en GitHub	Consistencia entre vistas manual
Mermaid C4	Sintaxis orientada a C4	Funcionalidad experimental
PlantUML + C4-PlantUML	Notación C4 madura y flexible	Definiciones duplicadas entre archivos si no se centralizan
Structurizr DSL	Modelo único y vistas derivadas	Mayor complejidad de tooling y exportación

Decisión

Adoptar Structurizr DSL como fuente editable autoritativa para C4 L1, L2 y L3. Los diagramas complementarios de secuencia, estados y despliegue utilizan Mermaid; no se mantienen fuentes PlantUML paralelas

Justificaciones independientes

1. Consistencia semántica: los elementos y relaciones se definen una vez y se reutilizan en vistas C4 de diferente nivel; se reduce el riesgo de representar dos arquitecturas incompatibles

2. Separación modelo-presentación: los detalles del diseño no dependen del motor de diagramación; la generación de SVG y otras salidas puede evolucionar sin duplicar la arquitectura fuente

Consecuencias

Mantener seis vistas vigentes a un workspace común

Mantener identificadores canónicos, límites de sistema y contenedor y relaciones etiquetadas

Aumentar la disciplina de validación DSL, exportación, revisión visual y control de cambios

Eliminar fuentes y exportaciones C4 históricas del árbol activo; Git conserva la historia

Documentar las relaciones condicionadas por contratos, sin presentarlas como implementadas

Validación

1. Ejecutar CLI validate sobre

2. Exportar las seis vistas con versión de CLI fijada

3. Inspeccionar SVG sin recortes y con etiquetas legibles

4. Contrastar relaciones con contratos, decisiones, secuencias y despliegue

5. Regenerar los diagramas del documento final desde el workspace validado

Estado: DSL de seis vistas validado visualmente por el responsable en Structurizr Playground (2026-11-09). La exportación de los dos SVG de contenedores al repositorio y la comprobación automatizada de seis SVG siguen pendientes

Referencias técnicas

ADR 008 third party fraud decisioning

Campo	Valor
Estado	Propuesto — sujeto a contrato del proveedor y apetito de riesgo
Alcance	Onboarding, autenticación sensible, beneficiarios, transferencias y pagos
Decisión	Integrar un proveedor antifraude mediante puerto/adaptador desacoplado; la autorización final sigue siendo responsabilidad de BP
Alternativas	Motor propio; reglas locales exclusivamente; proveedor externo con reglas locales de contingencia
Requisitos relacionados	Seguridad, integridad, privacidad, auditoría y resiliencia

Contexto y alternativas

El fraude incluye apropiación de cuentas, ingeniería social, cuentas mula, beneficiarios nuevos, cambios de dispositivo, bots, abuso de onboarding y transferencias no autorizadas. Un proveedor externo acelera la incorporación de señales y modelos, pero introduce latencia, dependencia, riesgos de privacidad y explicabilidad

Opción	Beneficio	Costo/riesgo	Decisión
Motor interno	Control de datos y modelos	Requiere equipo antifraude, señales y mantenimiento	No seleccionado inicialmente
Reglas locales solamente	Baja dependencia y latencia	Detección limitada de patrones complejos	Solo controles básicos complementarios
Proveedor externo + política BP	Señales/modelos especializados y gobierno local	Contrato, disponibilidad, costo, datos y explicabilidad	Propuesto

Flujo de autorización

1. Canal y backend validan autenticación, titularidad, límites, estado de sesión y dispositivo; ningún score reemplaza estos controles

2. Construir solicitud minimizada de riesgo con operationId, referencia seudónima de actor/dispositivo, tipo, monto, moneda, beneficiario seudónimo, antigüedad de beneficiario, canal y señales autorizadas

3. Invocar adaptador antifraude por API privada o TLS/mTLS según contrato; correlación e idempotencia por operationId + riskAssessmentVersion

4. Normalizar respuesta del proveedor a ALLOW | CHALLENGE | REVIEW | BLOCK | UNAVAILABLE, con decisionId, modelVersion, reasonCodes, expiresAt

5. Aplicar política BP: ALLOW continúa a autorización financiera; CHALLENGE exige step-up y revaluación; REVIEW retiene orden sin enviarla al Core; BLOCK rechaza y audita; UNAVAILABLE aplica política de contingencia

6. Persistir evidencia mínima de evaluación, versión de política y decisión antes de enviar orden financiera. La decisión de riesgo se ata a un hash canónico del comando; un cambio de importe/beneficiario invalida la aprobación

7. Para pagos/transferencias de alto riesgo, la indisponibilidad del proveedor implica fail-closed o revisión manual, no aprobación silenciosa. Operaciones de bajo riesgo pueden aplicar límites y reglas locales solo mediante política aprobada

Seguridad y privacidad

Proveedor bajo due diligence de seguridad, residencia, subprocesadores, uso de datos para entrenamiento, retención, respuesta a incidentes y derecho de auditoría

No enviar contraseñas, tokens, plantillas biométricas ni datos completos de cuenta salvo necesidad legal/contractual validada

Autenticación mutua, allowlist, protección de callbacks/webhooks (firma, replay, ventana temporal), timeouts y circuit breaker

Distinguir evaluación de fraude de controles AML/sanciones; el proveedor antifraude no sustituye cumplimiento AML, KYC o screening

Controles frente a falsos positivos: motivos trazables, revisión humana, apelación, métricas por segmento y auditoría de cambios de política

Evitar sesgos y decisiones automatizadas sin evaluación legal aplicable

Resiliencia y límites

Timeout del proveedor antes del envío Core: RISK_PENDING o REVIEW_REQUIRED, sin débito. Timeout después de decisión: consultar por decisionId o repetir solo evaluación idempotente; nunca duplicar orden bancaria. Reglas locales deben ser versionadas, firmadas y probadas; no exponer razones sensibles al atacante

Escenarios de validación

ID	Riesgo/ataque	Resultado
FRD-01	Nuevo dispositivo + beneficiario nuevo + monto elevado	CHALLENGE/REVIEW según política
FRD-02	Manipulación de monto después de ALLOW	Rechazo por hash de operación
FRD-03	Score fraudulento falsificado	Rechazo por autenticación e integridad de respuesta
FRD-04	Proveedor no responde	Alto riesgo no llega al Core
FRD-05	Respuesta duplicada o tardía	Idempotencia, expiración y correlación
FRD-06	Falso positivo	Revisión humana auditable
FRD-07	Reenvío de solicitud	Sin nueva orden financiera
FRD-08	Fuga de señales sensibles	Pruebas de minimización, acceso y retención

Estado de evidencia: escenarios definidos, no ejecutados. Contrato, umbrales, tratamiento de datos y niveles de servicio pendientes

ADR 009 iso20022 swift mx integration

Campo	Valor
Estado	Propuesto / supuesto de integración
Decisión	Modelo canónico de pagos con adaptadores ISO 20022 MX y perfiles SWIFT CBPR+ cuando corresponda
Alcance	Transferencias interbancarias internacionales o flujos conectados a SWIFT
No implica	Que toda transferencia doméstica use SWIFT ni que BP tenga conexión directa a SWIFT
Dependencias	Core, gateway de mensajería bancario, participante SWIFT, contratos de red y versiones de esquemas

Contexto y elección

Se propone incorporar mensajes ISO 20022 MX a través de un gateway bancario autorizado, preferentemente mediado por el Core o infraestructura de pagos institucional. ISO 20022 es un estándar de modelado y mensajes; SWIFT MX/CBPR+ son perfiles de uso para determinados flujos transfronterizos. La aplicabilidad a pagos nacionales requiere confirmar reglas del sistema de pagos local

Alternativa	Ventajas	Riesgos	Evaluación
API propietaria Core únicamente	Menor complejidad en canal	Dependencia del Core, interoperabilidad limitada	Mantener como ruta alternativa
Integración directa SWIFT desde canal	Control de envío	Seguridad, membresía, certificación y responsabilidad elevadas	No recomendada
Adaptador MX detrás de gateway bancario	Separación de contratos y trazabilidad	Validación estricta, evolución de versiones y conciliación	Propuesta

Mensajes y semántica

Mensaje	Uso conceptual	Restricción
pacs.008	Transferencia de crédito de cliente entre instituciones	Perfil CBPR+ y versión acordados
pacs.002	Reporte de estado de pago	No asumir que todos los estados equivalen a liquidación final
pacs.004	Devolución de pago	Reglas, causales y correlación contractuales
camt.056	Solicitud de cancelación	Solicitud, no reverso garantizado
camt.029	Resolución/investigación de solicitud	Semántica según esquema/perfil
pain.001	Iniciación de pago cliente a banco, si aplica	No reemplaza pacs.008 interbancario

Pipeline y fronteras

Comando autenticado -> autorización BP -> decisión antifraude -> idempotencia/estado local -> adaptador de pagos -> modelo canónico -> mapeo MX -> validación XSD + reglas de perfil -> gateway bancario -> red autorizada

Los mensajes de respuesta entran por gateway, se validan y correlacionan con operationId, BizMsgIdr y referencias de transacción acordadas. Nunca asumir equivalencia entre MsgId, InstrId, EndToEndId y TxId; su unicidad y uso dependen del contrato

Validaciones obligatorias

1. XML bien formado; XSD exacto y versionado; reglas CBPR+ aplicables además del XSD
2. Validación de campos estructurados de ordenante y beneficiario, incluidos Dbtr, Cdtr y direcciones según versión/perfil vigente; no asumir que un campo presente satisface la regla de negocio
3. Restricciones de moneda, importe, agente, BIC, referencias, longitud, caracteres, fechas y listas de códigos
4. Protección XML: deshabilitar DTD/entidades externas (XXE), límites de tamaño/profundidad y parsing seguro
5. Firma/autenticidad y canal de transporte según el gateway; cifrado, segregación de claves, trazabilidad y control de acceso
6. Duplicados por referencias de negocio y mensaje; correlación de respuestas; cuarentena para mensajes inválidos
7. Control de versiones de XSD/CBPR+, pruebas de contrato con participantes y ventanas de migración
8. Validación AML/sanciones en el sistema institucional correspondiente; antifraude y screening son controles distintos

Integridad y estados

El Core o sistema de pagos institucional conserva el registro autoritativo; BP guarda estado de orquestación

ACCEPTED a nivel de gateway no significa SETTLED ni COMPLETED para el cliente

Timeout de transporte o pacs.002 no concluyente => PENDING_RECONCILIATION; consulta por referencia y escalamiento, sin reenvío ciego

pacs.004 no es compensación ACID automática; requiere tratamiento contable y estado propio

Los mensajes MX pueden contener PII financiera; no registrar XML completo en logs o trazas; almacenamiento cifrado con retención definida

Trade-offs

La estandarización mejora interoperabilidad y trazabilidad, pero exige gobierno de esquemas, certificación, gestión de versiones, validaciones adicionales y operación especializada. Un adaptador anticorrupción evita filtrar estructuras XML a servicios de dominio y canales

Pruebas propuestas

MX-01 XSD válido; MX-02 regla CBPR+ inválida con XSD válido; MX-03 Dbtr incompleto; MX-04 XXE; MX-05 duplicado; MX-06 estado intermedio; MX-07 timeout y conciliación; MX-08 cambio de versión. MX-01..08 implementadas como pruebas sintéticas de laboratorio en ; ejecución posterior a esta modificación pendiente. La suite no ejecuta XSD oficial ni validación real de CBPR+, firma, gateway o screening; MX-01 comprueba estructura XML y campos sintéticos, no conformidad XSD

Decisiones abiertas

Tipo de pagos cubiertos; rol del participante SWIFT; gateway, transporte, esquema y release CBPR+ vigente; validación de datos estructurados; screening y sanciones; contrato de Core y reglas de conciliación

Endurecimiento sintético de mensajes y correlación

El laboratorio de referencia incorpora control de namespace exacto, deduplicación por MsgId con comprobación de contenido, correlación operationId ↔ referencia remota y una compuerta explícita de evidencia de finalidad antes de aceptar estados terminales. Estas medidas se prueban con test_mx_security.py; no equivalen a autenticación criptográfica de mensajes, XSD/CBPR+ oficial ni homologación con gateway. Su ejecución posterior a esta actualización está pendiente

ADR 010 apache camel core integration

Campo	Decisión
Estado	Propuesto, condicionado al contrato real del Core
Contexto	BP Digital Banking; INT-001/002/006, FIN-01..09, SEC-05/16
Decisión	Incorporar Apache Camel embebido en el adaptador de integración cuando existan múltiples protocolos, transformaciones o rutas legacy; no crear ESB central por defecto
Alternativa sencilla	Cliente HTTP/SOAP nativo Spring Boot cuando una única API estable no requiera EIP
Alternativa no elegida	ESB central compartido para toda la lógica de negocio
Aprobación	Arquitectura, Core, Seguridad, Operaciones BP — pendiente

1. Motivación y límites

El diseño existente ya define puertos/adaptadores hexagonales, Core Banking Adapter, Routing Policy, Reconciliation Coordinator, idempotencia local y outbox. Camel es una implementación interna posible del adaptador, no reemplaza estos componentes. Un despliegue separado solo se justifica por ownership, escalado o protocolos especiales (por ejemplo MQ), tras evaluar latencia y operaciones

2. Responsabilidades

Capa	Responsabilidad	No debe hacer
Servicio Transacciones	Autorización, titularidad, antifraude, idempotencia, estados y outbox	Conocer rutas Camel, SOAP o colas del Core
Puerto CoreOperationsPort	submit(reference,command) y lookup(reference) con resultado tipado	Asumir respuesta remota concluyente por HTTP 200
Adaptador Camel	Mapeo canónico, validación, conectores, correlación, timeout, observabilidad, autenticación de transporte	Reglas financieras, decisión antifraude, reintentos ciegos
Core	Registro autoritativo, débito y estado remoto	Depender de la BD local BP
Reconciliation Coordinator	Consulta de estado por referencia y escalamiento	Reemitir un débito tras timeout ambiguo

3. Patrones Camel permitidos

Message Translator: DTO canónico BP ↔ formato Core; validar importes exactos, moneda, referencias y errores

Content-Based Router: selección de ruta desde política previamente aprobada, no a partir de datos de cliente no confiables

Request/Reply: consultas y comandos cuando el protocolo del Core soporte respuesta correlacionada

Circuit Breaker/Timeout/Bulkhead: proteger dependencias; instrumentar con métricas y límites. La apertura del circuito no significa rechazo definitivo de una operación enviada

Idempotent Consumer: útil para callbacks/eventos duplicados, pero requiere repositorio durable compartido. No sustituye reserva transaccional de clave de negocio ni idempotencia del Core

Dead Letter Channel: únicamente para mensajes cuya reentrega sea segura o tras conciliación; nunca reentregar una orden de débito ambigua

4. Política de errores y reintentos

Operación	Reintento automático	Resultado ante timeout ambiguo
Consulta de saldo/movimientos	Limitado, con presupuesto y backoff si es segura	Error/degradación sin inventar datos
Consulta de estado por referencia	Sí, limitada y observable	Continuar conciliación o escalar
Transferencia/pago (débito)	No, salvo garantía contractual verificable de idempotencia extremo a extremo	PENDING_RECONCILIATION
Publicación de evento outbox	Sí, con deduplicación en consumidor	Pendiente de entrega, sin revertir Core
Evaluación antifraude	Solo evaluación idempotente, si contrato lo admite	REVIEW_REQUIRED / fail-closed

Un timeout antes de tener evidencia de no envío también puede ser ambiguo. El adaptador devuelve UNKNOWN, preserva externalReference y evita convertir errores de red en REJECTED. Se deben definir pruebas de crash, concurrencia multiinstancia y consulta remota por referencia

5. Despliegue AWS propuesto

Opción inicial: Camel en proceso Spring Boot del adaptador del servicio Transacciones sobre ECS Fargate Multi-AZ. El Core se alcanza mediante conectividad privada VPN/Direct Connect según contrato; secretos en Secrets Manager, IAM mínimo, TLS/mTLS cuando aplique, SG y egress restringido. No se requiere Amazon MQ por usar Camel: solo introducir broker si el Core realmente exige mensajería. Camel no reemplaza API Gateway, EventBridge/SQS, outbox ni Aurora

Escalar a contenedor dedicado: únicamente si el Core requiere conectores legacy compartidos, protocolos no compatibles con la aplicación, ciclos de despliegue independientes o aislamiento de capacidad. En ese caso se deben añadir HA multi-AZ, límites de concurrencia, autenticación entre servicios, observabilidad y control de cambios de contrato

6. Consecuencias y criterios de adopción

Beneficios: desacoplamiento de protocolos, rutas legibles, pruebas con endpoints simulados y menor código repetitivo para integración heterogénea

Costos: curva de aprendizaje Camel, superficie de dependencias, latencia adicional potencial, observabilidad de rutas y riesgo de usar EIP en exceso

Regla de selección: si el Core ofrece una API REST estable y un único protocolo, mantener adaptador HTTP simple. Adoptar Camel cuando se confirme SOAP/MQ/formatos propietarios, transformación no trivial o múltiples rutas. No fijar versión Camel ni dependencias hasta confirmar compatibilidad con Spring Boot/JDK y política de vulnerabilidades

7. Validación de aceptación

1. Contratos por operación y protocolo; pruebas de traducción y códigos de error

2. FIN-01/02/03/07 y crash/restart con repositorio durable; conteo de invocaciones remotas

3. Timeout tras efecto remoto -> conciliación, cero reenvíos de débito

4. TLS/mTLS, autenticación y secretos, sanitización de PII, trazas por operationId sin payload sensible

5. Prueba de HA/DR, límites de conexiones, carga y latencia con presupuesto acordado

6. Revisión de contrato Core, idempotencia por referencia y consulta de estado antes de aprobar producción

Estado: decisión de arquitectura documentada; no hay implementación Camel ni validaciones ejecutadas de rutas

Anexo — contratos, solicitudes, respuestas y mensajería

Alcance: ejemplos sintéticos de la arquitectura de referencia. No contienen datos reales ni representan contratos homologados con Core, proveedor antifraude, red interbancaria, IdP o servicios de notificación. Los ejemplos HTTP ilustran el contrato OpenAPI del canal financiero y las decisiones de integración bancaria descritas en este documento. El XML MX es una representación conceptual parcial y no un mensaje pacs.008/pacs.002 válido ni certificación XSD/CBPR+

A1. OpenAPI — transferencia interbancaria

RQ HTTP / JSON — POST /transfers; Idempotency-Key obligatoria:

```
POST /transfers HTTP/1.1
Authorization: Bearer <token>
Idempotency-Key: trf-20261106-001
Content-Type: application/json

{
  "type": "INTERBANK",
  "sourceAccountId": "acc-demo-001",
  "destination": {
    "bankCode": "DEMO01",
    "accountRef": "masked-demo-987"
  },
  "amount": "125.40",
  "currency": "USD",
  "concept": "Pago de ejemplo"
}
```

RS HTTP 202 / JSON — intención aceptada, no liquidación:

```
{
  "operationId": "op-demo-001",
  "status": "RECEIVED",
  "correlationId": "corr-demo-001",
  "statusUrl": "/transfers/op-demo-001"
}
```

Consulta: GET /transfers/op-demo-001 para el titular autorizado; los estados SUBMITTED, PENDING_RECONCILIATION, COMPLETED o REJECTED se determinan por evidencia, no por un simple 202. Reutilizar la clave con payload distinto genera 409

A2. OpenAPI — pago

RQ HTTP / JSON — estructura alineada con PaymentRequest del OpenAPI versionado:

```
POST /payments HTTP/1.1
Authorization: Bearer <token>
Idempotency-Key: pay-demo-20261109-001
Content-Type: application/json

{
  "sourceAccountId": "acc-demo-001",
  "beneficiaryRef": "biller-demo-001",
  "amount": "48.25",
  "currency": "USD",
  "concept": "Factura demo 001"
}
```

RS HTTP 202 / JSON — respuesta lógica ilustrativa:

```
{
  "operationId": "op-pay-demo-001",
  "status": "RECEIVED",
  "correlationId": "corr-pay-demo-001",
  "statusUrl": "/payments/op-pay-demo-001"
}
```

Consulta: GET /payments/op-pay-demo-001; el estado final depende de confirmación del proveedor/Core. No repetir órdenes financieras tras timeout ambiguo

A3. Antifraude — evaluación previa al despacho

RQ lógico / JSON (esquema externo por contratar):

```
{
  "operationId": "op-demo-001",
  "actorRef": "actor-demo-01",
  "operationHash": "sha256:synthetic-digest",
  "amount": "125.40",
  "currency": "USD",
  "correlationId": "corr-demo-001"
}
```

RS lógico / JSON:

```
{
  "operationId": "op-demo-001",
  "decision": "CHALLENGE",
  "policyVersion": "demo-v1",
  "expiresAt": "2026-11-09T15:05:00Z",
  "correlationId": "corr-demo-001"
}
```

Decisiones previstas: ALLOW, CHALLENGE, REVIEW, BLOCK, UNAVAILABLE. La decisión se vincula a hash, vigencia y versión de política; no sustituye titularidad ni AML/sanciones

A4. ISO 20022 / SWIFT MX — pacs.008 (mapeo conceptual)

RQ lógico hacia el adaptador MX:

```
{
  "operationId": "op-demo-001",
  "externalReference": "BP-DEMO-001",
  "messageType": "pacs.008",
  "debtor": {"name": "Cliente Ejemplo", "accountRef": "masked-origin"},
  "creditor": {"name": "Beneficiario Ejemplo", "accountRef": "masked-dest"},
  "amount": "125.40",
  "currency": "USD"
}
```

Fragmento XML ilustrativo — NO válido por sí solo como pacs.008 completo:

```
<FIToFICstmrCdtTrf>
  <CdtTrfTxInf>
    <PmtId><EndToEndId>BP-DEMO-001</EndToEndId></PmtId>
    <IntrBkSttlmAmt Ccy="USD">125.40</IntrBkSttlmAmt>
    <Dbtr><Nm>Cliente Ejemplo</Nm></Dbtr>
    <Cdtr><Nm>Beneficiario Ejemplo</Nm></Cdtr>
  </CdtTrfTxInf>
</FIToFICstmrCdtTrf>
```

Faltan elementos y envolturas obligatorios del esquema/perfil aplicable. El gateway debe validar XSD, reglas CBPR+ si corresponden, formato estructurado de partes, autenticidad, protección XXE y correlación BizMsgIdr/MsgId/InstrId/EndToEndId/TxId según contrato

A5. ISO 20022 — pacs.002 / resultado remoto

RS lógico normalizado (no un XML pacs.002 oficial):

```
{
  "externalReference": "BP-DEMO-001",
  "messageType": "pacs.002",
  "providerStatus": "PENDING",
  "operationStatus": "PENDING_RECONCILIATION",
  "correlationId": "corr-demo-001"
}
```

Un ACK de transporte o aceptación técnica no implica liquidación. Mapear códigos reales del esquema y del perfil contractual antes de marcar COMPLETED o REJECTED

A6. Outbox / EventBridge / SQS — cambio de estado

Evento lógico transaction.status.changed.v1:

```
{
  "eventId": "evt-demo-001",
  "eventType": "transaction.status.changed.v1",
  "operationId": "op-demo-001",
  "status": "COMPLETED",
  "occurredAt": "2026-11-09T15:10:00Z",
  "correlationId": "corr-demo-001",
  "recipientRef": "recipient-demo-01"
}
```

RS de procesamiento interno (registro de deduplicación, no respuesta de SQS):

```
{
  "eventId": "evt-demo-001",
  "consumer": "notification-service",
  "result": "PROCESSED",
  "duplicate": false
}
```

El outbox se confirma con el estado local; la entrega al bus es al menos una vez y requiere deduplicación. No incluir tokens, números completos de cuenta ni biometría en eventos

A7. Onboarding facial — callback firmado

RQ lógico recibido (payload sintético; autenticación del callback se verifica fuera del cuerpo):

```
{
  "verificationId": "ver-demo-001",
  "sessionId": "session-demo-001",
  "decision": "APPROVED",
  "issuedAt": "2026-11-09T15:12:00Z",
  "nonce": "nonce-demo-001",
  "correlationId": "corr-onb-demo-001"
}
```

RS de aceptación del callback (ilustrativo):

```
{
  "verificationId": "ver-demo-001",
  "received": true,
  "processingStatus": "ACCEPTED"
}
```

Verificar firma, timestamp, nonce, idempotencia y replay; registrar decisión y referencia, no plantilla biométrica. Habilitar credenciales en IdP únicamente tras verificación aprobada y política aplicable

A8. Trazabilidad y limitaciones

Ejemplo	Contrato / decisión	Criterio de verificación del diseño
A1–A2	OpenAPI canal, INT-002, FIN-01..09	Contratos Core/pagos, pruebas de errores, titularidad y conciliación
A3	INT-007, ADR-008	Contrato de proveedor, firma, vigencia, decisiones y fail-closed
A4–A5	INT-008, ADR-009	XSD y perfil CBPR+ aplicables, estados reales, gateway y correlación
A6	INT-003, auditoría/outbox	Duplicados, DLQ, retención, reconciliación
A7	INT-004, ADR-003	Firma y replay de callbacks, protección de datos

No se atribuye ejecución real ni homologación a estos mensajes de ejemplo

Síntesis arquitectónica y conclusiones

La solución propone canales web y móvil desacoplados de las capacidades bancarias mediante BFF, APIs y adaptadores de integración. El Core mantiene la responsabilidad sobre saldos y movimientos, mientras los servicios digitales administran el estado de las operaciones, las autorizaciones y la experiencia de usuario.

La integridad financiera se sustenta en idempotencia, máquina de estados, conciliación de respuestas ambiguas y publicación transaccional mediante outbox. La seguridad se aborda con identidad federada, autorización por recurso, antifraude previo al despacho, protección de datos y auditoría trazable.

El despliegue de referencia en AWS utiliza servicios administrados, separación de redes, múltiples zonas de disponibilidad, observabilidad y procedimientos de recuperación. Los objetivos de capacidad, continuidad y los contratos con Core y terceros son parámetros de diseño que se concretan durante la adopción institucional.

En conjunto, los diagramas C4, los flujos de secuencia, las decisiones arquitectónicas y los contratos ilustrativos describen una solución coherente, extensible y mantenible para BP Digital Banking. El documento presenta el diseño propuesto, sin atribuirle certificaciones o despliegues productivos.